

ELASTIC

FEDERAL COMPLIANCE

M-26-14

Reference Architecture

Federal Logging Compliance Pack for Elastic Stack

MEMORANDUM

OMB M-26-14 (May 2026)

PACK VERSION

0.1.0

ELASTIC STACK

8.16+ / 9.x

LICENSE REQUIRED

Enterprise

DATE

June 2026

M-26-14 Federal Logging Compliance — Reference Architecture

Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x | License: Enterprise required

This document is the unified reference architecture for the M-26-14 compliance pack on Elastic. It covers the full system — from log source to attestation evidence — with persona-oriented navigation, embedded architecture diagrams, and links to detailed sub-documents for each domain.

Quick Navigation by Persona

Persona	What you need	Start here
CISO / Deputy CISO	Strategic compliance posture, maturity overview, attestation	§1 Executive Summary → §3 Compliance Coverage → §10 Operational Model
ISSO / Compliance Officer	Requirement-by-requirement mapping, POA&M, reporting cadence	§3 Compliance Coverage → §5 Data Architecture → §10 Operational Model
Security Engineer / Architect	Deployment, sizing, integration, security controls, network	§4 Deployment Patterns → §6–§9
SOC Analyst	Alert triage, detection rule coverage, ML alerts	§2.3 Detection Coverage → §10 Operational Model
CIO / Inspector General / CISA Auditor	Compliance evidence, coverage matrix, attestation artifacts	§1 Executive Summary → §3.1 Coverage Matrix → §11 CISA LRA Alignment

Document Map

docs/	
├ reference-architecture.md	← you are here (unified RA)
├ compliance-walkthrough.md	← full requirement-to-implementation mapping
├ gap-analysis.md	← initial gap analysis + resolution decisions
├ ra-integration-architecture.md	← CDM/HWAM, CISA AIS, SOAR, Splunk detail
├ ra-security-architecture.md	← TLS, RBAC, audit logging, integrity detail
├ ra-network-architecture.md	← port table, firewall rules, zones detail
├ ra-sizing-capacity.md	← node specs, storage estimates, ILM sizing
└ ra-operational-model.md	← SOC workflow, CISA notifications, POA&M
diagrams/	
├ ra-overview.md	← Mermaid: end-to-end source-to-output
├ ra-data-flow.md	← Mermaid: pipeline internals, ILM lifecycle
├ ra-cloud.md	← Mermaid: FedRAMP / Elastic Cloud variant
├ ra-on-prem.md	← Mermaid: on-prem / air-gapped variant
└ svg/	
├ ra-overview.svg	← SVG: end-to-end architecture
├ ra-data-flow.svg	← SVG: pipeline + tier + detection flow
├ ra-integration.svg	← SVG: external integration points
└ ra-network-zones.svg	← SVG: network zone placement

1. Executive Summary

OMB Memorandum M-26-14 (May 22, 2026) supersedes M-21-31 and establishes two mandatory compliance objectives for all U.S. federal agencies:

CEM — Comprehensive Enterprise Monitoring Agencies must collect and retain logs from all asset types listed in Appendix B §5(a)–(k): endpoints, network infrastructure, DNS/DHCP, cloud platforms, OT/ICS, identity systems, and email/collaboration. Logs must meet M-26-14 retention thresholds (tiered by agency risk designation) and be searchable and retrievable on demand.

THIRF — Threat Hunt / Intelligence / Risk / Forensics Agencies must actively detect threats using the collected logs, integrate threat intelligence, and maintain tamper-evident log integrity. THIRF requires documented detection coverage across all 11 Appendix B categories, ML-assisted anomaly detection, and the capability to produce forensic evidence chains.

1.1 What This Pack Delivers

Compliance Objective	Elastic Delivery Mechanism
CEM — log collection	Elastic Agent + Fleet (50+ integrations), Logstash, Beats
CEM — retention tiers	5 ILM policies: L3 and L4 hot/frozen, asset inventory
CEM — asset inventory	CDM/HWAM httpjson integration + Osquery → logs-m2614.hwam-default
THIRF — detection	39 custom M-26-14 rules + ~1,800 prebuilt Elastic Security rules
THIRF — ML anomaly detection	6 custom M-26-14 ML jobs + 13 ML alert rules
THIRF — threat intelligence	CISA AIS + MS-ISAC TAXII 2.1 → Indicator Match rules
THIRF — tamper-evident logs	SHA-256 ingest pipeline → log.hash.sha256 (Element 5)
Appendix C maturity measurement	5 ML jobs (one per element) + Maturity Dashboard
Attestation evidence	Compliance Attestation Dashboard + coverage matrix export

1.2 Compliance Outcomes

Deploying this pack provides evidence against:

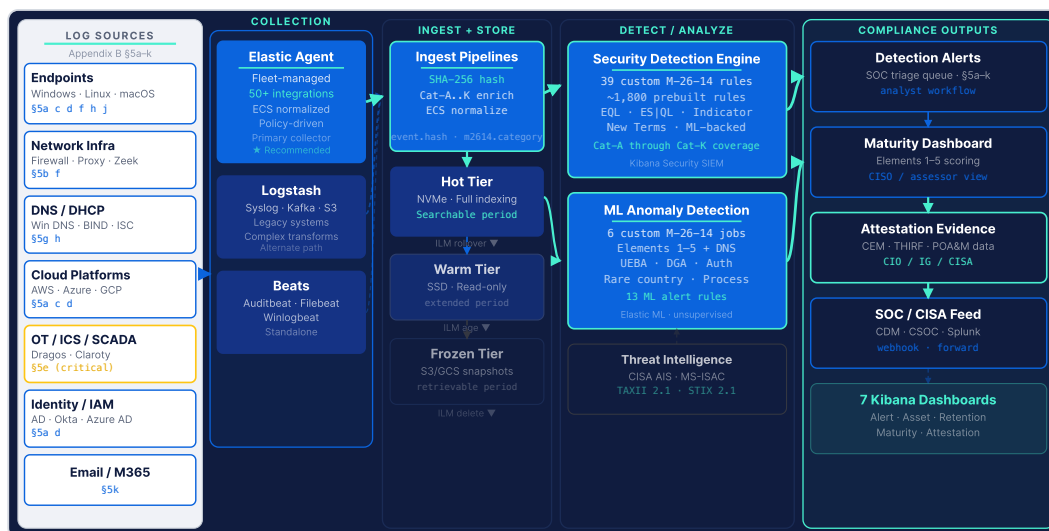
- All 5 Appendix C maturity elements (E1–E5)
- All 11 Appendix B §5 log categories (Cat-A through Cat-K)
- THIRF detection requirements for C2, exfiltration, lateral movement, OT incidents, APT chain detection
- CEM ingestion rate and searchable/retrievable retention requirements

1.3 Constraints and Prerequisites

- **Elastic Enterprise license** required (ML anomaly detection + Watcher)
- **Hot + Frozen tier** required (object storage: S3, GCS, or Azure Blob for Frozen)
- **Fleet Server** deployment required for Elastic Agent management
- **Agency must classify** its retention tier (L3 vs L4) per M-26-14 Appendix C before sizing
- **CISA AIS registration** required for live TAXII threat intel feeds
- This pack addresses the Elastic platform layer; OT/ICS sensor deployment (Dragos, Claroty) is out of scope and must be coordinated with OT teams

2. Architecture Overview

The diagram below shows the end-to-end system: log sources through collection, ingest pipelines, Elasticsearch tiers, detection and ML analysis, and compliance outputs.



End-to-end architecture

Full-resolution: [ra-overview.svg](#) | Mermaid version: [ra-overview.md](#)

2.1 Component Descriptions

Log Sources (Appendix B §5a-k) Seven source categories must all be represented to satisfy CEM. Each maps to one or more Appendix B §5 categories:

Source	Appendix B §5	Primary Integration
Endpoints (Windows/Linux/macOS)	§5(a) auth, §5(c) file ops, §5(d) priv escalation, §5(f) EDR tamper, §5(h) DHCP, §5(j) process	Elastic Endpoint, Winlogbeat, Auditbeat
Network Infrastructure	§5(b) C2/beaconing, §5(f) network traffic	Packetbeat, firewall syslog via Logstash
DNS / DHCP	§5(g) DNS, §5(h) DHCP	Zeek DNS integration, Windows DNS Server integration
Cloud Platforms	§5(a) auth, §5(c) storage, §5(d) IAM config	AWS CloudTrail, Azure Activity Log, GCP Audit Logs
OT / ICS / SCADA	§5(e) OT asset + threat	Dragos integration, Claroty (via syslog)
Identity / IAM	§5(a) SSO/MFA, §5(d) AD changes	Active Directory, Okta, Azure AD integrations
Email / Collaboration	§5(k) email	Microsoft 365, Google Workspace integrations

Collection Layer Elastic Agent (Fleet-managed) is the primary collector. It handles ECS normalization at the integration layer and applies the `m2614-log-integrity-settings` component template (which wires `log-integrity-hash` as the final pipeline) to all `logs-m2614.*` data streams. Logstash handles legacy syslog, Kafka, and S3 sources. Beats provide lightweight collection for specific use cases.

Ingest Pipeline Layer Three pipelines execute in sequence on ingestion: 1. `ecs-logstash-normalize` — ECS field normalization 2. `log-integrity-hash` — SHA-256 hash of event fields → `log.hash.sha256` (Element 5) 3. `alert-category-pipeline` — tags M-26-14 detection alerts with `m2614.category` (Cat-A through Cat-K)

Elasticsearch Data Tiers ILM policies move indices through Hot (NVMe, full indexing, searchable retention) → Warm (SSD, read-only) → Frozen (object storage, searchable snapshots, retrievable retention) → Delete.

Detection Engine (THIRF) Kibana Security SIEM with 39 custom `m2614-appendixb-a-*` through `m2614-appendixb-k-*` detection rules, each tagged to the corresponding Appendix B category. Rules use EQL, ES|QL, Indicator Match, and New Terms techniques.

ML Anomaly Detection (CEM maturity measurement) Six custom ML jobs continuously monitor compliance health: - `element1-asset-coverage` — detects drops in log source variety (CEM scope) - `element2-ingestion-rate` — detects ingestion rate anomalies (CEM rate) - `element3-rule-silence`

— detects categories going undetected (THIRF coverage) - `element4-privop-spike` — detects privileged operation anomalies (Element 4) - `element5-hash-coverage` — detects drops in SHA-256 coverage (Element 5) - `catb-dns-entropy` — DGA detection via DNS entropy analysis (§5g)

Compliance Outputs - Detection Alerts → SOC triage queue (Kibana Security Alerts) - Maturity Dashboard → Element 1–5 scoring for CISO/assessors - Attestation Dashboard → CEM + THIRF closed-loop evidence for CIO/IG/CISA - SOC/CISA Feed → alert forwarding to CSOC, CDM, or Splunk - 7 Kibana dashboards (see §3.3)

2.2 Data Flow Summary

See [ra-data-flow.svg](#) and [ra-data-flow.md](#) for the detailed internal data flow.

High-level: raw events → ECS normalize → SHA-256 hash → index to Hot tier → ILM lifecycle → detection rules query Hot tier → ML jobs query Hot tier → alerts enriched with `m2614.category` → dashboards + SOC + CISA feed.

2.3 Detection Coverage

Appendix B Category	Rule Bundle	Detection Techniques	CISA Notifiable
Cat-A: Authentication	m2614-appendixb-a- * (6 rules)	Brute force, impossible travel, off-hours auth	Confirmed lateral movement
Cat-B: C2/Beaconing	m2614-appendixb-b- * (4 rules)	Beacon periodicity, DNS entropy, known-bad IoC	Yes — confirmed C2
Cat-C: Mass File Ops	m2614-appendixb-c- * (3 rules)	Unusual file volume, zip/exfil pattern	If sensitive systems
Cat-D: Priv Escalation	m2614-appendixb-d- * (4 rules)	Privilege grants, service account abuse	Yes — if credential compromise
Cat-E: OT/ICS	m2614-appendixb-e- * (5 rules)	Dragos/Claroty alert enrichment, protocol anomalies	Yes — OT safety impact
Cat-F: EDR Tamper	m2614-appendixb-f- * (3 rules)	Agent disable/uninstall, log purge, policy change	Yes
Cat-G: IoC Match	m2614-appendixb-g- * (3 rules)	DNS Indicator Match, IP/domain feed match	Yes — confirmed IoC
Cat-H: Off-Hours	m2614-appendixb-h- * (2 rules)	DHCP + auth off-hours pattern (UEBA)	If escalation follows
Cat-I: File Access	m2614-appendixb-i- * (3 rules)	Sensitive path access, bulk file read	If data exfil follows
Cat-J: Exfiltration	m2614-appendixb-j- * (3 rules)	Large outbound transfer, DNS exfil, staged data	Yes — confirmed exfil
Cat-K: APT Chain	m2614-appendixb-k- * (3 rules)	Multi-stage correlation, email + endpoint + network	Yes — all APT chains

3. Compliance Coverage

Full detail: [compliance-walkthrough.md](#)

3.1 CEM and THIRF Coverage Matrix

Requirement	Covered	Evidence	Maturity Dashboard
CEM: All §5(a)–(k) sources collected	✓	<code>logs-*</code> data streams + Fleet agent deployment coverage	Element 1 score
CEM: Ingestion rate maintained	✓	<code>element2-ingestion-rate</code> ML job + alert	Element 2 score
CEM: Searchable retention (L3/L4)	✓	<code>m2614-l3-hot-frozen</code> / <code>m2614-l4-hot-frozen</code> ILM policies	Retention Compliance dashboard
CEM: Retrievable retention (L3/L4)	✓	Frozen tier with searchable snapshots	Retention Compliance dashboard
CEM: Asset inventory (HWAM)	✓	<code>logs-m2614.hwam-default</code> via httpjson + osquery	Asset Coverage dashboard
THIRF: Detection rules for all categories	✓	39 custom rules across all 11 categories	Element 3 score
THIRF: Threat intelligence integration	✓	CISA AIS + MS-ISAC TAXII → <code>logs-ti_*</code>	Appendix B Coverage Matrix
THIRF: ML anomaly detection	✓	6 ML jobs + 13 alert rules	Maturity Overview dashboard
THIRF: Tamper-evident logs	✓	<code>log-integrity-hash</code> pipeline + <code>integrity_verify.py</code>	Element 5 score

3.2 Appendix C Maturity Element Coverage

Element	Description	ML Job	Alert Rule	Dashboard
E1: Asset Coverage	All §5 source types reporting	element1-asset-coverage	m2614-ml-e1-coverage-drop	Asset Coverage
E2: Ingestion Rate	Consistent volume from all sources	element2-ingestion-rate	m2614-ml-e2-ingestion-drop	Log Management
E3: Rule Coverage	No category going undetected	element3-rule-silence	m2614-ml-e3-rule-silence	Appendix B Coverage Matrix
E4: Privileged Ops	Privileged operations monitored	element4-privop-spike	m2614-ml-e4-retention-anomaly	Alert Coverage by Category
E5: Log Integrity	SHA-256 coverage maintained	element5-hash-coverage	m2614-ml-e5-hash-drop	Maturity Overview

3.3 Kibana Dashboard Inventory

Dashboard	Primary Audience	Purpose
Compliance Attestation	CIO, IG, CISA Auditor	Closed-loop CEM + THIRF coverage matrix, export-ready
Maturity Overview	CISO, Deputy CISO	Element 1–5 scores with trend over time, navigation drilldowns
Appendix B Coverage Matrix	ISSO, Compliance Officer	Category-by-category rule coverage status
Alert Coverage by Category	SOC Lead, ISSO	Alert volume and distribution by Cat-A..K
Asset Coverage	Security Engineer, ISSO	Fleet agent deployment + HWAM asset inventory cross-reference
Log Management	Security Engineer, SOC Lead	Ingestion rate trends, index health, ILM phase status
Retention Compliance	Security Engineer, ISSO	Index age, ILM transitions, hot/warm/frozen status per data stream

4. Deployment Patterns

4.1 Choosing Your Deployment Pattern

Choose your deployment pattern based on:

Is FedRAMP High authorization required?

- └ Yes → Is agency already on Elastic Cloud for US Government?
 - └ Yes → Cloud variant (see §4.2)
 - └ No → Evaluate: timeline < 90 days? → Cloud variant
 - else: either
- └ No → Is the environment air-gapped or classified?
 - └ Yes → On-Premises Air-Gapped (see §4.3)
 - └ No → Is there an existing on-prem Elastic deployment?
 - └ Yes → Extend existing + add M-26-14 pack (§4.4)
 - └ No → New On-Premises deployment (§4.3) or Cloud variant (§4.2)

4.2 Cloud / FedRAMP High

Elastic Cloud for US Government provides the fastest path to FedRAMP High authorized deployment. The platform handles inter-node TLS, zone placement, load balancing, certificate management, and ILM.

Key characteristics: - FedRAMP High ATO — direct inheritance benefit for agency ATO process -

Available: AWS GovCloud (us-gov-west-1, us-gov-east-1), Azure Government (usgovvirginia, usgovtexas)

- IP filter allowlists for restricting inbound access to SOC CIDR ranges - Private endpoint / VPC peering option for eliminating public internet traffic - Autoscaling hot tier

Full diagram: [diagrams/ra-cloud.md](#)

Pack deployment in cloud:

```
# Configure environment for cloud
ES_HOST=https://your-deployment.es.us-gov-west-1.aws.found.io
KIBANA_HOST=https://your-deployment.kb.us-gov-west-1.aws.found.io
# Deploy pack
elastic-package install
```

4.3 On-Premises / Air-Gapped

On-premises deployment in agency data center. Supports air-gapped (no internet connectivity) environments.

Key characteristics: - Full agency control over hardware, network, and crypto - Supports FIPS 140-2 hardware HSMs for key management - Air-gapped variant: TAXII feeds delivered via scheduled file transfer or removable media - mTLS between all nodes using agency PKI CA-signed certificates

Full diagram: [diagrams/ra-on-prem.md](#)

4.4 Hybrid

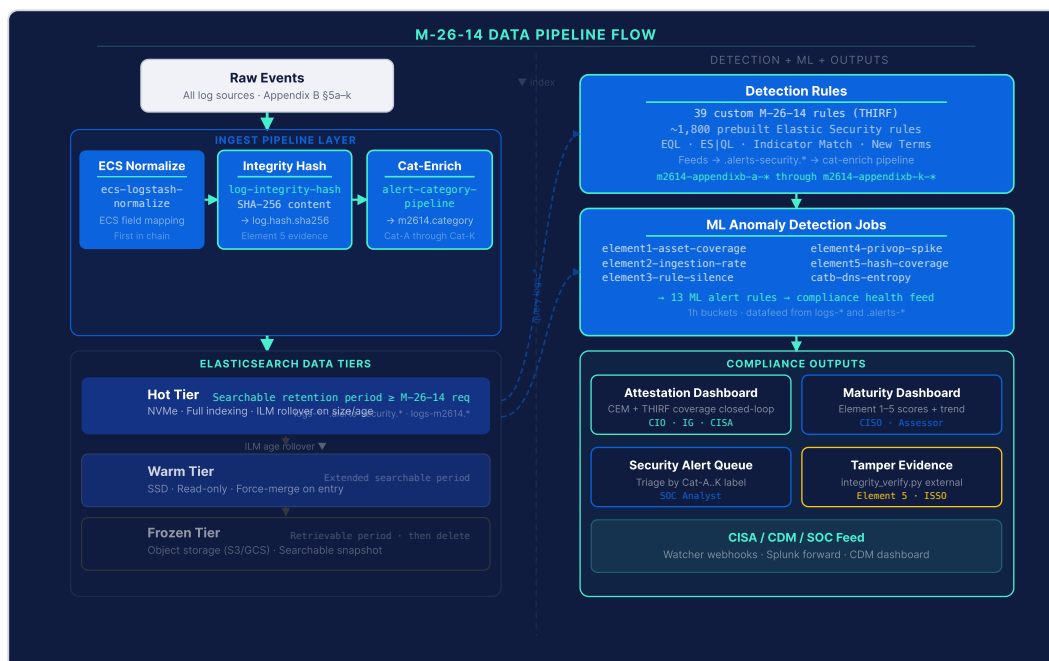
Some agencies run Elasticsearch on-premises but use cloud object storage (AWS GovCloud S3 or Azure Government Blob) for the Frozen tier. This reduces on-premises storage requirements while keeping hot/warm data on-prem.

Frozen tier configuration:

```
# elasticsearch.yml – cloud storage for frozen snapshots
xpack.searchable.snapshot.shared_cache.size: 100gb
# S3 repository configured via _snapshot API
```

5. Data Architecture

5.1 Data Streams and Index Strategy



Data Pipeline Flow

Full detail: [ra-data-flow.md](#) | SVG: [ra-data-flow.svg](#)

All logs are stored as Elasticsearch data streams. The `m2614-log-integrity-settings` component template wires the SHA-256 pipeline as `final_pipeline` for any data stream matching `logs-m2614.*`, ensuring all pack-specific data has integrity hashing.

Data Stream	Source	M-26-14 Function
<code>logs-*</code>	All integrations	General log storage; ML datafeed source
<code>.alerts-security.*</code>	Detection engine	Element 3 ML datafeed; THIRF output; Cat enrichment
<code>logs-m2614.hwam-default</code>	CDM/httpjson + osquery	Element 1 asset coverage cross-reference
<code>logs-m2614.integrity_violations-default</code>	Integrity pipeline	Element 5 tamper evidence
<code>logs-elasticsearch.audit-*</code>	ES audit logging	Element 4 privileged-op monitoring
<code>logs-zeek.dns-default</code>	Zeek DNS	Cat-B/G DNS entropy ML job
<code>logs-dragos.asset-*</code>	Dragos integration	§5(e) OT asset inventory
<code>logs-dragos.alert-*</code>	Dragos integration	§5(e) OT threat detection
<code>logs-ti_*</code>	CISA AIS / MS-ISAC	Threat intel; Indicator Match rules

5.2 ILM Retention Tiers

M-26-14 defines retention tiers by agency risk designation. Confirm your tier with your CISA contact:

ILM Policy	Hot Phase	Frozen Phase	Delete	Target Agency
<code>m2614-l3-hot-frozen</code>	Searchable for ≥ required searchable period	Retrievable for remainder of retention period	After retention expiry	Standard agencies (L3)
<code>m2614-l4-hot-frozen</code>	Extended searchable period	Extended retrievable period	After L4 retention expiry	High-risk agencies (L4, CISA-designated)
<code>m2614-asset-inventory</code>	90-day rolling	N/A	After 90 days	HWAM asset records

ILM phases: - **Hot**: NVMe storage, full indexing, force-merge on rollover (50 GB max shard) - **Warm**: SSD, read-only replica, optional shrink - **Frozen**: Object storage (S3/GCS/Azure Blob), searchable snapshot, 3-5x compression

5.3 ECS Field Mapping

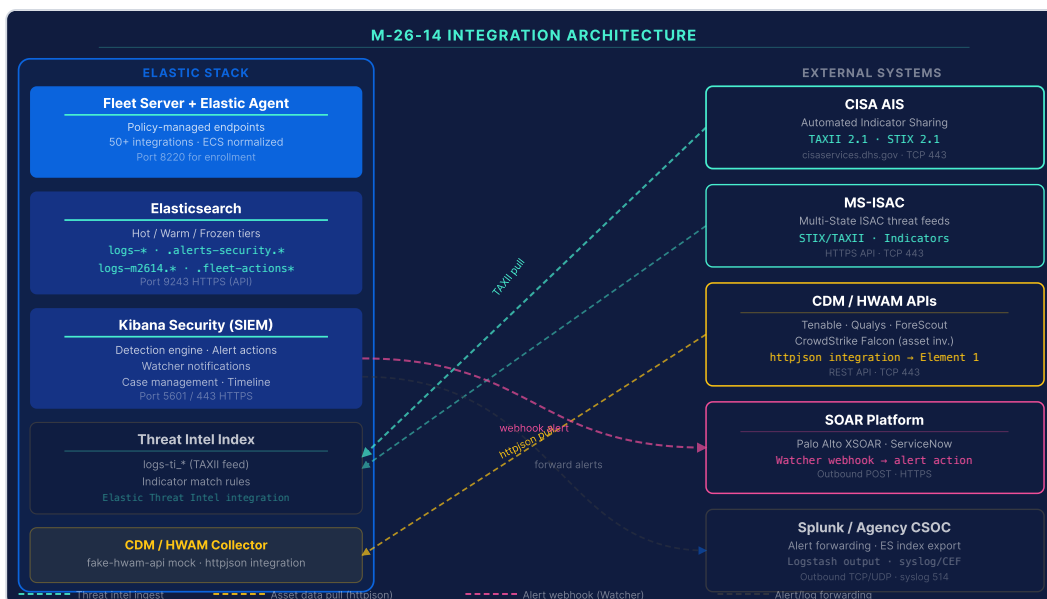
All events are normalized to [Elastic Common Schema \(ECS\)](#)

(<https://www.elastic.co/guide/en/ecs/current/index.html>). Key M-26-14-specific fields added by ingest pipelines:

Field	Type	Added By	Purpose
<code>log.hash.sha256</code>	keyword	<code>log-integrity-hash</code> pipeline	Element 5 tamper detection
<code>m2614.category</code>	keyword	<code>alert-category-pipeline</code>	Cat-A..K label on alerts
<code>event.module</code>	keyword	Integration	Source integration identifier
<code>agent.type</code>	keyword	Elastic Agent	ML job grouping field
<code>agent.id</code>	keyword	Elastic Agent	Asset coverage tracking

6. Integration Architecture

Full detail: [ra-integration-architecture.md](#)



Integration Architecture

SVG: [ra-integration.svg](#)

The M-26-14 pack integrates with five external systems. All integrations use HTTPS/TLS; no plaintext connections to external endpoints.

Integration	Direction	Protocol	Purpose	Required
CISA AIS	Inbound to ES	TAXII 2.1 / HTTPS	Threat indicators → Indicator Match	Yes (THIRF)
MS-ISAC	Inbound to ES	STIX/TAXII / HTTPS	Additional threat feeds	Recommended
CDM / HWAM APIs	Outbound from ES	httpjson / HTTPS	Asset inventory → Element 1	Yes (CEM)
SOAR Platform	Outbound from Kibana	Webhook / HTTPS	Alert response automation	Recommended
Splunk / CSOC	Outbound from Logstash	HEC / HTTPS	Alert forwarding	Agency-specific

CISA AIS: The Elastic Threat Intelligence integration polls CISA's TAXII 2.1 endpoint for STIX 2.1 indicators. Indicators populate `logs-ti_*` data streams. Indicator Match detection rules reference this index to fire

alerts when a log event matches a known-bad indicator. Requires agency registration with CISA AIS program.

CDM / HWAM: The `fake-hwam-api` tool (in `tools/fake-hwam-api/`) simulates Tenable, Qualys, ForeScout, and CrowdStrike REST APIs for integration testing. Replace with production API endpoints when deploying. The `httpjson` integration polls these APIs on a schedule and writes normalized asset records to `logs-m2614.hwam-default`, which the `element1-asset-coverage` ML job uses to cross-reference against active log sources.

SOAR: Kibana Watcher triggers on high-severity M-26-14 alerts (Cat-B, Cat-E, Cat-J, Cat-K) and fires a webhook to the agency SOAR platform. The SOAR platform then executes the appropriate playbook (network containment, OT isolation, etc.) and creates a ticket that links back to the Kibana Case.

7. Security Architecture

Full detail: [ra-security-architecture.md](#)

7.1 Encryption in Transit

All communication is TLS 1.2 or higher: - ES node-to-node: mTLS on port 9300 (transport layer) - ES HTTP API: TLS on port 9243 - Kibana ↔ ES: TLS on port 9243 - Agent ↔ Fleet Server: TLS on port 8220 - Browser ↔ Kibana: HTTPS on port 443

7.2 Authentication

Kibana supports SAML 2.0 / OIDC for agency SSO integration (Active Directory Federation Services, Okta, Azure AD). Native Elasticsearch authentication is available for service accounts and break-glass access.

7.3 Authorization (RBAC)

Five recommended roles scoped to M-26-14 operational needs:

Role	Scope
m2614_soc_analyst	Read alerts, read logs, run saved queries
m2614_compliance_officer	Above + write cases, read all dashboards
m2614_security_engineer	Stack admin (no cluster admin)
m2614_ciso_viewer	Read-only across all M-26-14 indices + dashboards
m2614_fleet_admin	Fleet/Agent management, ingest pipeline management

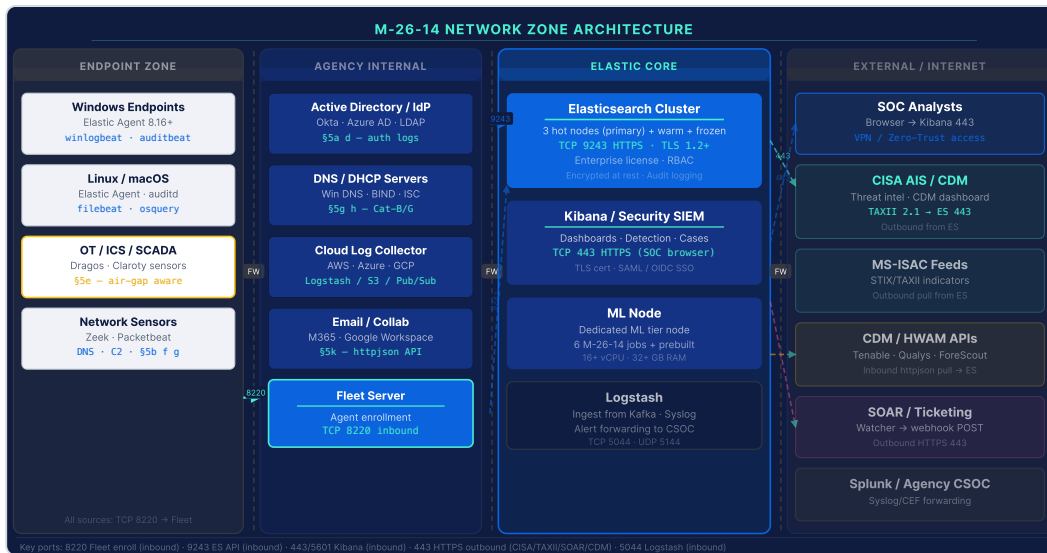
7.4 Log Integrity (Element 5)

The `log-integrity-hash` ingest pipeline computes `SHA-256(message + @timestamp + host.name + event.action)` on every event and stores the result in `log.hash.sha256`. The `integrity_verify.py` tool can re-compute hashes from source logs and compare against indexed values to detect tampering.

```
# Run tamper detection spot-check
python tools/integrity_verify.py --host $ES_HOST --index "logs-m2614.*" --sample 1000
```

8. Network Architecture

Full detail: [ra-network-architecture.md](#)



Network Zones

SVG: [ra-network-zones.svg](#)

8.1 Zone Summary

Zone	Components	Trust
Endpoint Zone	Workstations, servers, OT/ICS, network sensors	Low–Medium
Agency Internal	AD/IdP, DNS/DHCP, cloud collectors, email	Medium
Elastic Core	Elasticsearch cluster, Kibana, Fleet Server, ML nodes	High
External / Internet	CISA AIS, CDM APIs, SOAR, SOC browsers	Untrusted (TLS only)

8.2 Key Firewall Rules

Flow	Port	Direction	Notes
Elastic Agent → Fleet Server	8220/TCP	Inbound to Core	TLS required; source = endpoint CIDRs
Fleet/Logstash/Beats → ES	9243/TCP	Inbound to Core	TLS required
SOC browser → Kibana	443/HTTPS	Inbound to Core	Restrict to SOC CIDR + VPN
ES → CISA AIS / TAXII	443/HTTPS	Outbound from Core	Allow by FQDN only
ES → CDM APIs	443/HTTPS	Outbound from Core	Tenable/Qualys/ForeScout FQDNs
Kibana (Watcher) → SOAR	443/HTTPS	Outbound from Core	Webhook destination
Logstash → Splunk HEC	8088/HTTPS	Outbound from Core	Optional; disable if unused

9. Sizing and Capacity

Full detail: [ra-sizing-capacity.md](#)

9.1 Quick Sizing Reference

Agency Size	Endpoints	EPS	Daily Volume	Hot Nodes	Frozen Storage
Lab / POC	< 100	< 100	< 10 GB	1 (all-in-one)	None
Small	< 2,000	~500	~180 GB	3	~10 TB (L3)
Medium	2,000–20,000	~3,000	~1 TB	6–9	~65 TB (L3)
Large	20,000+	10,000+	~3+ TB	15+	~200+ TB (L3)

Note: All production deployments require minimum 3 hot data nodes (for replica shards and resiliency). Lab/POC single-node is not supported for production.

9.2 Minimum Node Specs (Small Agency)

Node Role	Count	vCPU	RAM	Storage
Hot data	3	8	32 GB	2 TB NVMe each
Warm data	1	4	16 GB	4 TB SSD
Frozen / coordinating	1	4	16 GB	500 GB (data on S3)
ML node	1	16	32 GB	200 GB SSD
Kibana	1	4	8 GB	100 GB
Fleet Server	2	2	4 GB	50 GB each

9.3 ILM Sizing

Frozen tier uses S3/GCS object storage. Expect 3–5× compression vs raw event volume. L4 agencies should budget approximately 2.5× storage of L3 estimates.

10. Operational Model

Full detail: [ra-operational-model.md](#)

10.1 SOC Alert Triage

M-26-14 detection alerts arrive in Kibana Security → Alerts, tagged with `m2614.category`. Triage priority:

Priority	Categories	Response SLA	CISA Notify
P1	Cat-B (C2), Cat-E (OT)	Escalate within 1 hour	Yes, if confirmed
P2	Cat-H (off-hours), Cat-J (exfil), Cat-K (APT)	Investigate within 4 hours	Yes, if confirmed
P3	Cat-A, C, D, F, G, I	Investigate within 24 hours	If escalation follows

All true-positive M-26-14 alerts must be documented in Kibana Cases with `m2614.category`, affected asset, disposition, and CISA notification status.

10.2 CISA Notification

M-26-14 THIRF requirements mandate CISA notification for confirmed: - APT activity (Cat-K chains, Cat-A lateral movement) - C2 to known-bad infrastructure (Cat-B) - Confirmed exfiltration (Cat-J combined with Cat-K) - OT/ICS incidents with safety potential (Cat-E)

Watcher rules on Cat-B, Cat-E, Cat-J, Cat-K alerts can auto-trigger SOAR playbooks that draft CISA notifications. See [ra-operational-model.md](#) → §2 for notification format and timeline.

10.3 POA&M and Quarterly Review

Agencies must maintain a POA&M for any Appendix C element not fully met. The Maturity Dashboard shows continuous element scores; ML alert rules automatically signal when an element drops below baseline.

Quarterly review cadence: Jan 31, Apr 30, Jul 31, Oct 31 (POA&M updates to CISA).

10.4 Key Operational Commands

```
# Check ML job status
python tools/coverage_refresh.py

# Run integrity tamper check
python tools/integrity_verify.py --host $ES_HOST --index "logs-m2614.*"

# Seed ML demo baseline (21-day synthetic)
python tools/seed_ml_demo_data.py

# Bulk-enable detection rules
python tools/setup_ws5.py --enable

# Deploy dashboards
python tools/setup_ws7_dashboard.py
```

11. CISA LRA Alignment

Status: Placeholder — CISA Logging Reference Architecture (LRA) expected ~August 2026.

CISA is developing a Logging Reference Architecture (LRA) that will define the canonical federal logging stack architecture. This pack will be reviewed and updated within 30 days of LRA publication to ensure alignment.

Anticipated LRA areas that may require pack updates: - Specific TAXII endpoint and API format requirements - Prescribed data stream naming conventions - Mandatory alert notification fields and formats - Cross-agency log sharing architecture

Track this section: when LRA publishes, create a GitHub issue to review each LRA section against the pack. The gap-analysis.md process used during initial development provides the review template.

Appendix A: Port and Protocol Reference

See the full port table in [ra-network-architecture.md](#) → Appendix A.

Summary of required inbound ports (Elastic Core):

Port	Protocol	Component	Source
8220	TCP/TLS	Fleet Server	Elastic Agents (endpoint zone)
9243	HTTPS	Elasticsearch	Fleet, Logstash, Beats, Kibana
9300	TCP/mTLS	ES transport	ES nodes only (cluster-internal)
443	HTTPS	Kibana (via reverse proxy)	SOC browsers (restrict by CIDR)
5044	TCP/TLS	Logstash Beats input	Beats agents

Summary of required outbound ports (Elastic Core):

Port	Protocol	Destination	Purpose
443	HTTPS	CISA AIS, MS-ISAC	TAXII threat intel pull
443	HTTPS	CDM API endpoints	HWAM asset data pull
443	HTTPS	SOAR platform	Watcher webhook
8088	HTTPS	Splunk HEC	Alert forwarding (optional)

Appendix B: Data Stream Inventory

Data Stream Pattern	Primary Source	Retention Policy	M-26-14 Function
<code>logs-*</code>	All integrations	<code>m2614-l3/l4-hot-frozen</code>	CEM log storage
<code>.alerts-security.*</code>	Detection engine	<code>m2614-l3/l4-hot-frozen</code>	THIRF alert output
<code>logs-m2614.hwam-default</code>	CDM httpjson + osquery	<code>m2614-asset-inventory</code>	Element 1
<code>logs-m2614.integrity_violations-default</code>	Integrity pipeline	<code>m2614-l3/l4-hot-frozen</code>	Element 5
<code>logs-elasticsearch.audit-*</code>	ES audit	<code>m2614-l3/l4-hot-frozen</code>	Element 4
<code>logs-zeek.dns-default</code>	Zeek	<code>m2614-l3/l4-hot-frozen</code>	Cat-B/G, DNS entropy ML
<code>logs-ti_*</code>	CISA AIS / MS-ISAC	90-day rolling	Threat intel / Indicator Match

Appendix C: Asset Summary

Category	Count	Key Assets
ML jobs	6	element1-asset-coverage, element2-ingestion-rate, element3-rule-silence, element4-privop-spike, element5-hash-coverage, catb-dns-entropy
ML datafeeds	9	6 compliance + 3 prebuilt auth supplements
ML alert rules	13	E1-E5 element alerts + Cat-A/B/H supplementary
Detection rules	39 custom + ~1,800 prebuilt	m2614-appendixb-a-* through m2614-appendixb-k-*
Ingest pipelines	3	log-integrity-hash, alert-category-pipeline, osquery-normalize
ILM policies	5	m2614-l3-hot-frozen, m2614-l4-hot-frozen, asset-inventory + variants
Index templates	5 + 1 component	m2614-logs-data-streams + m2614-log-integrity-settings component
Kibana dashboards	7	compliance attestation, maturity overview, Appendix B matrix, alert coverage, asset coverage, log management, retention compliance
Setup scripts	4	setup_ws3.py, setup_ws5.py, setup_ws6_source_data.py, setup_ws7_dashboard.py
CLI tools	2	integrity_verify.py, coverage_refresh.py
Demo seeders	2	seed_ml_demo_data.py (21-day synthetic), seed-demo-data/ (events)
Mock API server	1	fake-hwam-api (Tenable/Qualys/ForeScout/CrowdStrike simulator)
Test suites	2	ws1_ml_jobs/ (ML API tests), ws5_detection/ (rule validation)

Related Documents

Document	Description
compliance-walkthrough.md	Full requirement-to-implementation mapping, item by item
gap-analysis.md	Initial gap analysis, workstream decisions, resolution evidence
demo-guide.md	Step-by-step demo walkthrough of all 5 maturity elements
ml-jobs-guide.md	ML job reference: datafeed config, model reference, alert thresholds
ra-integration-architecture.md	CDM/HWAM, CISA AIS, SOAR, Splunk integration detail
ra-security-architecture.md	TLS, RBAC, audit logging, key management detail
ra-network-architecture.md	Port table, firewall rules, zone placement detail
ra-sizing-capacity.md	Node specs, storage estimates, ILM sizing by agency size
ra-operational-model.md	SOC triage workflow, CISA notifications, POA&M, quarterly review
diagrams/ra-overview.md	Mermaid: end-to-end architecture
diagrams/ra-data-flow.md	Mermaid: pipeline internals + ILM lifecycle
diagrams/ra-cloud.md	Mermaid: FedRAMP / Elastic Cloud deployment
diagrams/ra-on-prem.md	Mermaid: on-prem / air-gapped deployment

Integration Architecture

Integration Architecture — M-26-14 Compliance Pack

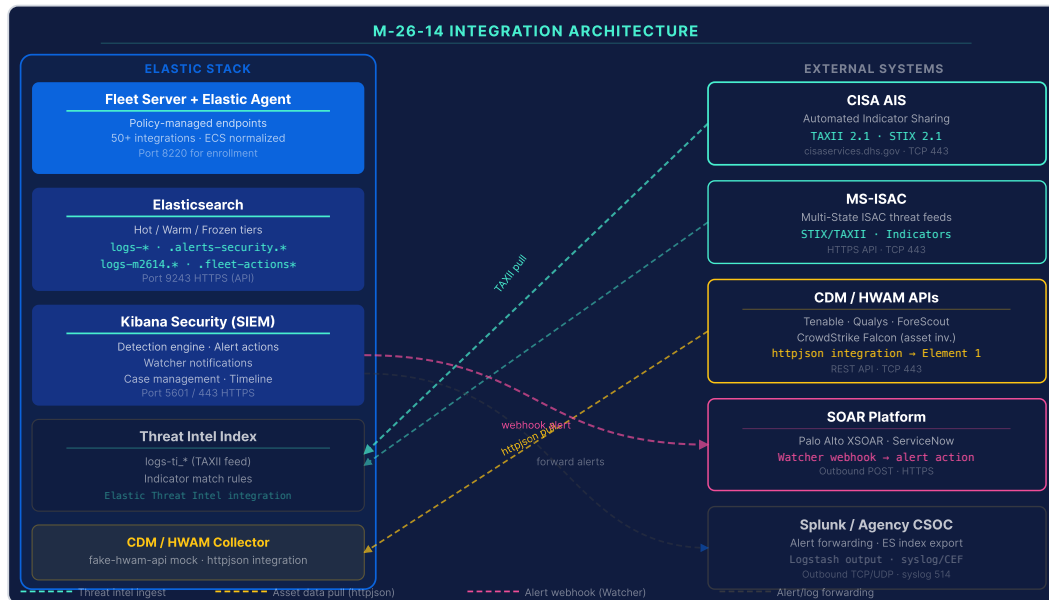
Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x

Overview

The M-26-14 Compliance Pack positions Elastic as the central data hub for federal agency logging and detection infrastructure. Elastic Agent and Fleet Server ingest telemetry from endpoints, network devices, cloud workloads, and identity platforms through 50+ integrations that normalize all data to the Elastic Common Schema (ECS). Elasticsearch stores and indexes that telemetry across hot, warm, and frozen ILM tiers according to M-26-14 retention requirements (90 days hot for Level 3, 12 months hot/18 months frozen for Level 4). Kibana Security SIEM surfaces the 39 custom M-26-14 detection rules alongside approximately 1,800 prebuilt rules, ML anomaly jobs, and compliance dashboards for every persona from SOC Analyst to CIO auditor.

External systems connect to this hub in two directions. Upstream sources — CISA AIS, MS-ISAC, and CDM/HWAM asset management platforms — push threat intelligence and asset inventory data into Elastic data streams where they enrich detection and maturity scoring. Downstream targets — SOAR platforms and agency CSOC Splunk instances — receive alerts and forwarded logs from Elastic for automated response and enterprise-wide visibility. The CISA CDM Dashboard integration closes the compliance reporting loop by surfacing Appendix C maturity element scores to the federal Continuous Diagnostics and Mitigation program. All integrations are managed through Fleet, allowing centralized policy enforcement, credential rotation, and audit logging of integration activity.

Diagram



Integration Architecture

1. CISA Automated Indicator Sharing (AIS)

Purpose

CISA AIS delivers machine-speed threat indicators to participating federal agencies via TAXII 2.1. Indicators are formatted as STIX 2.1 objects and include IP addresses, domains, file hashes, URLs, and email indicators associated with known threat actors targeting federal networks. Consuming AIS feeds in near real-time satisfies the M-26-14 §5b requirement for active threat detection through Cyber Event Monitoring (CEM) Category C (network anomaly) and Category B (network traffic) coverage.

Elastic Integration

The Elastic Threat Intel integration polls the CISA AIS TAXII server on a configurable interval, ingests STIX indicator bundles, and writes normalized indicator records to the `logs-ti_*` data stream family. Kibana Security Indicator Match rules then join those indicators against live event data streams — DNS logs, network flow, HTTP proxy, and endpoint telemetry — to generate alerts when a live observable matches a known-bad indicator.

TAXII flow:

```

CISA AIS TAXII 2.1 Server
|
| HTTPS poll (interval: 1h)
v
Elastic Threat Intel Integration (Fleet-managed)
|
| ECS-normalized STIX indicators
v
logs-ti_cisa.atp-default (ILM: 90-day retention)
|
| Indicator Match rule execution
v
.alerts-security.* (enriched with m2614.category = Cat-C)

```

Configuration Example

```

# fleet/integrations/threat-intel-taxii.yml
- name: cisa-ais-taxii
  type: ti_taxii
  enabled: true
  vars:
    url: "https://cisaservices.dhs.gov/taxii2/api/"
    username: "${CISA_AIS_USERNAME}"
    password: "${CISA_AIS_PASSWORD}"
    collection_id: "default"
    initial_interval: "24h"
    interval: "1h"
    min_indicator_age: "0h"
    itype:
      - ipv4-addr
      - domain-name
      - url
      - file
      - email-addr
  output:
    - logs-ti_taxii.threat-default

```

Store credentials in Fleet's secrets manager, not in the YAML directly. Rotate the `CISA_AIS_PASSWORD` secret every 90 days or on any AIS credential revocation notice.

Compliance Mapping

Requirement	Mapping
M-26-14 §5b	AIS indicators feed Indicator Match rules for C2 detection
CEM Category B	Network traffic indicators matched against proxy/DNS logs
CEM Category C	Command-and-control domain/IP indicators
THIRF Enrichment	<code>threat.indicator.*</code> fields appended to alert records
Appendix C E3	Indicator Match rules counted toward Rule Coverage

2. MS-ISAC Threat Feeds

Purpose

The Multi-State Information Sharing and Analysis Center (MS-ISAC) operates a TAXII 2.1 feed that supplements CISA AIS with indicators derived from state, local, tribal, and territorial (SLTT) government incident response. For federal agencies with shared infrastructure or third-party dependencies on SLTT systems, MS-ISAC indicators provide earlier warning on commodity ransomware, phishing kits, and web shell campaigns that may pivot into federal networks.

Elastic Integration

MS-ISAC is consumed through the same Elastic Threat Intel TAXII integration as CISA AIS, with a separate Fleet integration policy pointing to the MS-ISAC endpoint. Indicators land in a dedicated data stream to keep provenance visible in detection alerts.

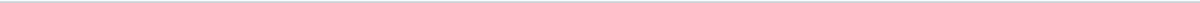
Configuration Example

```
# fleet/integrations/threat-intel-msisac.yml
- name: msisac-taxii
  type: ti_taxii
  enabled: true
  vars:
    url: "https://taxii.cisecurity.org/taxii2/api/"
    username: "${MSISAC_TAXII_USERNAME}"
    password: "${MSISAC_TAXII_PASSWORD}"
    collection_id: "ms-isac-indicators"
    initial_interval: "24h"
    interval: "2h"
    min_indicator_age: "0h"
    itype:
      - ipv4-addr
      - domain-name
      - url
      - file
  output:
    - logs-ti_taxii.msisac-default
```

Configure a separate Indicator Match rule set that references `logs-ti_taxii.msisac-default` so SLTT-sourced detections carry a distinct `rule.reference` value and can be filtered in dashboard views by indicator provenance.

Compliance Mapping

Requirement	Mapping
CEM Category B/C	Commodity threat indicators covering network and C2 categories
M-26-14 §5b	Active detection via threat-intel-enriched alerting
THIRF	<code>threat.feed.name: MS-ISAC</code> preserved in ECS for audit trail



3. CDM / HWAM API Integration

Purpose

M-26-14 Appendix C Element 1 (Asset Coverage) requires agencies to demonstrate that all authorized IT assets are enrolled in logging. The Continuous Diagnostics and Mitigation (CDM) program's Hardware Asset Management (HWAM) tools — Tenable Nessus/SecurityCenter, Qualys VMDR, ForeScout eyeSight, and CrowdStrike Falcon — maintain authoritative asset inventories. The integration polls each tool's API on a scheduled interval and writes normalized asset records to `logs-m2614.hwam-default`. The `coverage_refresh.py` script joins that inventory against the enrolled Elastic Agent population to calculate the Element 1 maturity score visible in the Asset Coverage dashboard.

Architecture

```
Tenable / Qualys / ForeScout / CrowdStrike APIs
|
| REST/JSON poll (httpjson integration, 15m interval)
v
Elastic Fleet httpjson Integration
|
| Normalized to m2614.hwam.* ECS extension fields
v
logs-m2614.hwam-default
|
| coverage_refresh.py daily join
v
Element 1 score → compliance attestation dashboard
```

For local testing and demo environments, the `fake-hwam-api` service bundled with the pack provides a mock REST server that emulates all four tool response schemas on `http://localhost:8080`.

Tool Reference Table

Tool	API Type	Data Stream	Notes
Tenable SecurityCenter	REST v2 (/rest/asset)	logs-m2614.hwam-default	Requires SC API key; pagination via startOffset
Qualys VMDR	REST v2 (/api/2.0/fo/asset/host/)	logs-m2614.hwam-default	Basic auth; XML response parsed to JSON in processor
ForeScout eyeSight	REST (/api/hosts)	logs-m2614.hwam-default	Token-based auth; rate limit 100 req/min
CrowdStrike Falcon	OAuth2 (/devices/queries/devices/v1)	logs-m2614.hwam-default	Client credentials grant; falcon.host_info mapped to HWAM fields

Configuration Example

```
# fleet/integrations/hwam-tenable.yml
- name: hwam-tenable
  type: httpjson
  enabled: true
  vars:
    url: "https://tenable.agency.gov/rest/asset"
    request_method: GET
    request_headers:
      X-ApiKey: "${TENABLE_API_KEY}"
      Content-Type: "application/json"
    interval: "15m"
    request_transforms:
      - set:
          target: url.params.fields
          value: "ip,uuid,hostname,os,lastSeen,pluginID"
    response_transforms:
      - set:
          target: event.dataset
          value: m2614.hwam
      - set:
          target: event.module
          value: m2614
      - rename:
          fields:
            - from: ip
              to: host.ip
            - from: hostname
              to: host.name
            - from: os
              to: host.os.full
            - from: uuid
              to: m2614.hwam.asset_id
            - from: lastSeen
              to: m2614.hwam.last_seen
  output:
    - logs-m2614.hwam-default
```

Substitute `fake-hwam-api` for the `url` value in development:

```
url: "http://localhost:8080/tenable/rest/asset"
```

Compliance Mapping

Requirement	Mapping
Appendix C E1	Asset inventory joined against enrolled agents for coverage %
CEM Category A	HWAM data supports endpoint identity in log events
CDM HWAM	Direct integration with CDM-accredited asset tools

4. SOAR Platform Integration

Purpose

M-26-14 THIRF (Threat Hunting and Incident Response Framework) requires that agencies not only detect events but initiate automated or analyst-assisted response workflows within defined time windows. Elastic Watcher watches the `.alerts-security.*` index for high-fidelity M-26-14 detection alerts and fires webhook actions to the agency SOAR platform. This ensures every alerted event of CEM Categories B through K enters a documented, auditable response workflow without manual triage initiation.

Architecture

```
.alerts-security.*
|
| Watcher schedule (every 1m)
v
Watcher condition: m2614.category exists AND signal.status = open
|
| Webhook action (HTTPS POST)
v
SOAR Platform (XSOAR / ServiceNow / Splunk SOAR / Generic)
|
| Playbook execution
v
Case record + enrichment → analyst queue
```

Supported Platforms

Platform	Integration Method	Notes
Palo Alto XSOAR	Watcher webhook → XSOAR REST API (<code>/incident</code>)	Map <code>kibana.alert.rule.name</code> to XSOAR <code>name</code> field
ServiceNow ITSM	Watcher webhook → ServiceNow Table API (<code>/api/now/table/sn_si_incident</code>)	Requires MID Server if ServiceNow is on-prem
Splunk SOAR	Watcher webhook → SOAR REST API (<code>/rest/event</code>)	Token auth; map <code>m2614.category</code> to Splunk SOAR <code>label</code>
Generic Webhook	Watcher webhook → any HTTPS endpoint	Full JSON body; no field mapping required at Elastic side

Watcher Action Configuration

```
{
  "trigger": {
    "schedule": {
      "interval": "1m"
    }
  },
  "input": {
    "search": {
      "request": {
        "indices": [".alerts-security.*"],
        "body": {
          "query": {
            "bool": {
              "filter": [
                { "exists": { "field": "m2614.category" } },
                { "term": { "kibana.alert.workflow_status": "open" } },
                {
                  "range": {
                    "@timestamp": {
                      "gte": "now-1m"
                    }
                  }
                }
              ]
            }
          }
        }
      }
    }
  },
  "condition": {
    "compare": {
      "ctx.payload.hits.total": {
        "gt": 0
      }
    }
  },
  "actions": {
    "notify_soar": {
      "webhook": {
        "method": "POST",
```

```
    "url": "${SOAR_WEBHOOK_URL}",
    "headers": {
      "Content-Type": "application/json",
      "Authorization": "Bearer ${SOAR_API_TOKEN}"
    },
    "body": "{{#toJson}}ctx.payload.hits.hits{/toJson}}"
  }
}
}
```

Store `SOAR_WEBHOOK_URL` and `SOAR_API_TOKEN` as Elasticsearch keystore entries. Reference them via `${VAR}` interpolation in the Watcher action body.

Alert Routing by Category

CEM Category	Playbook	Priority	SLA
Cat-B (Network Traffic)	Network containment — isolate source IP, block at perimeter firewall	P2	4 hours
Cat-C (Network Anomaly/C2)	C2 containment — DNS sinkhole, endpoint isolation, IOC expansion	P1	1 hour
Cat-D (DNS Activity)	DNS investigation — query history expansion, domain registration lookup	P2	4 hours
Cat-E (OT/ICS Traffic)	OT isolation — segment enforcement, ICS vendor notification	P1	1 hour
Cat-F (Identity/Auth)	Account lockout — disable account, force password reset, review MFA	P1	1 hour
Cat-G (User Activity)	Insider threat triage — manager notification, DLP review, HR escalation	P2	8 hours
Cat-H (Privileged Ops)	Privileged access review — session recording review, PAM ticket audit	P1	2 hours
Cat-I (Process/Execution)	Endpoint forensics — memory capture, process tree analysis, AV scan	P1	1 hour
Cat-J (File Activity)	DLP response — quarantine file, hash	P2	4 hours

CEM Category	Playbook	Priority	SLA
	comparison against known-bad		
Cat-K (Email)	Phishing response — message retraction, sender block, credential check	P2	4 hours

Compliance Mapping

Requirement	Mapping
THIRF automated response	Every open M-26-14 alert enters a SOAR playbook within 1 minute
M-26-14 §6	Documented incident response timelines satisfy THIRF SLA requirements
Appendix C E4	Privileged Ops (Cat-H) alerts routed to dedicated playbook for review

5. Splunk / Agency CSOC Forwarding

Purpose

Many federal agencies operate a centralized Security Operations Center (CSOC) with an existing Splunk Enterprise Security deployment. The M-26-14 Compliance Pack does not require replacement of that infrastructure. Instead, Logstash forwards a filtered copy of M-26-14 alert data and high-value log streams from Elasticsearch to the Splunk HTTP Event Collector (HEC), preserving existing CSOC workflows while adding Elastic's detection and compliance layer upstream.

Architecture

```
Elasticsearch (.alerts-security.*, logs-*)
|
| Elasticsearch input (scroll API)
v
Logstash pipeline (m2614-to-splunk.conf)
|
| Field rename + filter (drop non-M-26-14 events)
v
Splunk HEC output (port 8088 HTTPS)
|
v
Splunk Enterprise Security
```

Logstash Configuration

```
# /etc/logstash/conf.d/m2614-to-splunk.conf

input {
  elasticsearch {
    hosts => ["https://elastic.agency.gov:9243"]
    user => "${ES_LOGSTASH_USER}"
    password => "${ES_LOGSTASH_PASSWORD}"
    ssl => true
    ca_file => "/etc/logstash/certs/ca.crt"
    index => ".alerts-security.*,logs-m2614.*"
    query => '{"query": {"exists": {"field": "m2614.category"}}}'
    schedule => "* * * * *"
    scroll => "5m"
    size => 500
    docinfo => true
    docinfo_target => "[@metadata][es]"
  }
}

filter {
  mutate {
    rename => {
      "m2614.category" => "m2614_category"
      "event.action" => "event_action"
      "agent.name" => "agent_name"
      "@timestamp" => "event_time"
    }
    add_field => {
      "sourcetype" => "elastic:m2614:alert"
      "index" => "main"
    }
  }
  # Drop events already forwarded (use docinfo _id for dedup)
  if [@metadata][es][_index] =~ /^\.alerts/ {
    mutate { add_field => { "sourcetype" => "elastic:m2614:alert" } }
  } else {
    mutate { add_field => { "sourcetype" => "elastic:m2614:log" } }
  }
}

output {
```

```
http {  
  url ⇒ "https://splunk-hec.agency.gov:8088/services/collector/event"  
  http_method ⇒ "post"  
  headers ⇒ {  
    "Authorization" ⇒ "Splunk ${SPLUNK_HEC_TOKEN}"  
    "Content-Type" ⇒ "application/json"  
  }  
  format ⇒ "json"  
  mapping ⇒ {  
    "event"      ⇒ "%{message}"  
    "time"       ⇒ "%{event_time}"  
    "sourcetype" ⇒ "%{sourcetype}"  
    "index"      ⇒ "%{index}"  
    "host"       ⇒ "%{agent_name}"  
  }  
}  
}
```

Field Mapping Reference

Elastic Field	Splunk Field	Notes
<code>m2614.category</code>	<code>m2614_category</code>	Cat-A through Cat-K; used as Splunk <code>tag</code> for routing
<code>event.action</code>	<code>event_action</code>	ECS action verb; maps to Splunk CIM <code>action</code>
<code>agent.name</code>	<code>agent_name</code>	Elastic Agent hostname; maps to Splunk <code>host</code>
<code>@timestamp</code>	<code>event_time</code>	ISO 8601; Splunk HEC interprets as epoch automatically
<code>kibana.alert.rule.name</code>	<code>rule_name</code>	Detection rule that fired; Splunk ES correlation search reference
<code>host.ip</code>	<code>src_ip</code>	Source IP; maps to Splunk CIM <code>src</code>
<code>destination.ip</code>	<code>dest_ip</code>	Destination IP; maps to Splunk CIM <code>dest</code>
<code>user.name</code>	<code>user</code>	Identity; maps to Splunk CIM <code>user</code>
<code>threat.indicator.ip</code>	<code>threat_ip</code>	AIS/MS-ISAC indicator match; no Splunk CIM equivalent, use <code>threat_*</code> prefix
<code>log.hash.sha256</code>	<code>log_hash</code>	Tamper-evident hash from ingest pipeline; audit use only

Compliance Mapping

Requirement	Mapping
M-26-14 §7	Agencies may retain existing CSOC tooling while satisfying M-26-14 via Elastic
CEM integration	<code>m2614.category</code> preserved in forwarded events for CSOC analyst context
THIRF	Alerts forwarded within 1 minute of creation; SLA clock starts at Elastic alert time

6. CISA CDM Dashboard Integration

Purpose

M-26-14 requires agencies to report compliance metrics to CISA through the CDM Federal Dashboard. The Appendix C maturity element scores — E1 through E5 — must be calculated, attested, and transmitted at a cadence defined by CISA CDM program guidance. The Compliance Pack calculates all five element scores within Elasticsearch and surfaces them in the Kibana Compliance Attestation dashboard. Agencies export those scores via a scheduled Kibana report or API call and submit them to CISA CDM using the standard CDM Data Model schema.

Integration Flow



Field Mapping Guidance

Elastic Field / Metric	CDM Data Model Field	Notes
Element 1 score (agent coverage %)	HWAM_COVERAGE_PCT	From <code>coverage_refresh.py</code> output in <code>logs-m2614.hwam-default</code>
Element 2 score (ingestion rate)	LOG_INGESTION_RATE	ML job <code>element2-ingestion-rate</code> anomaly score
Element 3 score (rule coverage %)	RULE_COVERAGE_PCT	Ratio of active rules with recent alerts to total rules
Element 4 score (privileged ops %)	PRIVOP_COVERAGE_PCT	Cat-H events with PAM session context attached
Element 5 score (log integrity %)	LOG_INTEGRITY_PCT	Ratio of events with <code>log.hash.sha256</code> present
<code>@timestamp</code> of attestation	ATTESTATION_TIMESTAMP	UTC ISO 8601; included in each attestation submission
<code>agent.version</code>	AGENT_VERSION	Elastic Agent version; demonstrates tooling currency

Agencies should consult the CISA CDM Data Model specification (version current at time of submission) for exact field names and enumeration values, as the CDM data model is updated independently of this pack. The field names above reflect the logical mapping intent and must be translated to the current CDM schema version in the agency integration layer.

Appendix A: Integration Checklist

Integration	Required for M-26-14	Notes
CISA AIS (TAXII 2.1)	Required	Satisfies §5b active detection; CISA credentials required
MS-ISAC Threat Feeds	Recommended	Supplements AIS; particularly valuable for agencies with SLTT dependencies
CDM / HWAM API	Required	Element 1 score cannot be calculated without authoritative asset inventory
SOAR Platform	Required	THIRF mandates documented automated or analyst-initiated response workflows
Splunk / CSOC Forwarding	Conditional	Required only if agency CSOC operates Splunk ES as the system of record
CISA CDM Dashboard	Required	M-26-14 mandates periodic compliance metric reporting to CISA CDM

Appendix B: Troubleshooting

TAXII Not Updating

Symptom: The `logs-ti_taxii.*` or `logs-ti_taxii.msiscac-default` data streams show no documents newer than the integration's `initial_interval`.

Cause	Solution
Credentials expired or rotated at the TAXII server	Verify credentials with a manual <code>curl</code> against the TAXII discovery endpoint (<code>/taxii2/</code>). Update secrets in Fleet's secrets manager and redeploy the integration policy.
Network path blocked — proxy, firewall, or DNS	From the Elastic Agent host, run <code>curl -v https://cisaservices.dhs.gov/taxii2/api/</code> or the MS-ISAC equivalent. If the connection times out, open a ticket with the agency network team to permit outbound HTTPS to the TAXII server IP range on port 443.
TAXII collection ID changed	CISA and MS-ISAC occasionally rename or add TAXII collections. Query the collections endpoint (<code>/taxii2/api/collections/</code>) to retrieve current collection IDs and update the Fleet integration policy <code>collection_id</code> variable.

HWAM Polling Errors

Symptom: The `logs-m2614.hwam-default` data stream is empty or stops receiving updates. The Fleet integration status shows errors.

Cause	Solution
API key or token expired	Each HWAM tool rotates API credentials on its own schedule (Tenable: 90 days by default, Qualys: on demand, ForeScout: 1 year, CrowdStrike: configurable). Check the tool's admin console for credential expiry. Generate a new key and update the Fleet secret.
Asset management tool API rate limit exceeded	The httpjson integration default interval of 15 minutes may exceed the tool's API rate limit if the asset count is large. Increase the <code>interval</code> to <code>30m</code> or <code>1h</code> and add a <code>rate_limit_request_body_field</code> processor to respect the tool's <code>Retry-After</code> header.
<code>fake-hwam-api</code> not running in test environments	The development mock server must be started before Fleet attempts to poll. Run <code>docker-compose up -d fake-hwam-api</code> from the pack root. Verify it is reachable at <code>http://localhost:8080/health</code> . If the Fleet Agent is not on the same host, update the integration <code>url</code> to use the Docker host IP rather than <code>localhost</code> .

Watcher Webhook Failures

Symptom: Watcher history shows `condition_met: true` but the `notify_soar` action status is `failure` or the SOAR platform reports no incoming events.

Cause	Solution
SOAR webhook URL unreachable from Elasticsearch nodes	Elasticsearch Watcher executes webhook actions from the Elasticsearch node, not from a Kibana host or Logstash. Ensure the Elasticsearch node's egress firewall permits HTTPS to the SOAR platform's IP and port. Test with <code>curl -X POST \${SOAR_WEBHOOK_URL}</code> from the ES node shell.
API token invalid or revoked	SOAR platforms rotate bearer tokens on user session expiry or manual revocation. Regenerate the token in the SOAR admin console and update the Elasticsearch keystore: <code>bin/elasticsearch-keystore add xpack.notification.http.ssl...</code> then restart the watcher service with <code>POST _watcher/start</code> .
Payload too large for SOAR webhook receiver	Watcher sends the full <code>ctx.payload.hits.hits</code> array, which may exceed the SOAR receiver's body size limit if many alerts fire simultaneously. Add a <code>transform</code> to the Watcher action that limits the payload to the first 10 hits and projects only required fields: add a <code>script</code> transform extracting <code>ctx.payload.hits.hits[0..9]</code> and projecting <code>_source.m2614.category</code> , <code>_source.kibana.alert.rule.name</code> , and <code>_source.@timestamp</code> .

Security Architecture — M-26-14 Compliance Pack

Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x

Overview

The M-26-14 Compliance Pack is deployed as a layered security architecture that addresses five distinct control planes: transport encryption, authentication, authorization (RBAC), audit logging, and data integrity. Each layer is mandatory for a production federal deployment; weakening any single layer creates gaps that will surface during an FY-2027 CEM audit.

The architecture is designed for Elastic 8.16+ / 9.x running on Elastic Cloud (preferred) or self-managed on-premises in an air-gapped or FedRAMP High boundary. All communication between components uses TLS 1.2 or 1.3 at minimum. Authentication is federated via SAML or OIDC against an agency Identity Provider. Role-based access control enforces least-privilege across six named roles. Every privileged operation generates an audit event that feeds the element4-privop-spike ML job. Every log record ingested through the compliance data streams receives a SHA-256 hash that the element5-hash-coverage ML job continuously monitors.

The following diagram shows how each section maps to the Appendix C maturity elements:

Transport TLS	→	E1 (Asset Coverage): Agent → Fleet (8220) ensures endpoint enrollment
Authentication	→	E4 (Privileged Ops): SAML attr maps to m2614_ RBAC roles
RBAC	→	E4 (Privileged Ops): least-privilege enforced on SIEM actions
Audit Logging	→	E4 (Privileged Ops): elasticsearch + kibana audit data streams
Log Integrity	→	E5 (Log Integrity): SHA-256 per record, element5-hash-coverage ML

1. Transport Security (TLS)

1.1 Node-to-Node mTLS

Elasticsearch nodes communicate over TCP port 9300 using mutual TLS. Both the server and client certificates must be signed by the cluster CA. This prevents rogue nodes from joining the cluster and encrypts inter-node replication traffic, which includes all shard data and `.alerts-security.*` indices.

Channel	Port	Protocol	Certificate type
ES node ↔ ES node (transport)	9300	mTLS	PEM signed by cluster CA
ES ↔ Kibana (HTTP)	9243	TLS (server cert)	PEM or PKCS#12
Fleet Server ↔ Elasticsearch	9243	TLS (server cert)	PEM or PKCS#12
Elastic Agent ↔ Fleet Server	8220	TLS (server cert, optional mTLS)	Fleet-managed
Browser ↔ Kibana	443	TLS 1.2+	DigiCert / Let's Encrypt / Agency CA
Logstash ↔ Elasticsearch	9243	TLS (server cert)	PEM or PKCS#12
Beats ↔ Logstash	5044	TLS (server cert)	PEM or PKCS#12
Syslog receivers	5144	TLS (server cert)	PEM or PKCS#12

1.2 elasticsearch.yml TLS Configuration

```
# elasticsearch.yml – transport (node-to-node) and HTTP (client-facing) TLS

# --- Transport layer (port 9300) ---
xpack.security.transport.ssl.enabled: true
xpack.security.transport.ssl.verification_mode: certificate
xpack.security.transport.ssl.keystore.path: certs/elastic-certificates.p12
xpack.security.transport.ssl.truststore.path: certs/elastic-certificates.p12

# --- HTTP layer (port 9243) ---
xpack.security.http.ssl.enabled: true
xpack.security.http.ssl.keystore.path: certs/http.p12

# --- FIPS-approved cipher suites (required for FedRAMP High) ---
xpack.security.transport.ssl.cipher_suites:
  - TLS_AES_256_GCM_SHA384
  - TLS_AES_128_GCM_SHA256
  - TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
  - TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
xpack.security.http.ssl.cipher_suites:
  - TLS_AES_256_GCM_SHA384
  - TLS_AES_128_GCM_SHA256
  - TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
  - TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
```

1.3 kibana.yml TLS Configuration

```
# kibana.yml – Kibana HTTPS and back-end connection to Elasticsearch

server.ssl.enabled: true
server.ssl.certificate: /etc/kibana/certs/kibana.crt
server.ssl.key: /etc/kibana/certs/kibana.key
server.ssl.supportedProtocols: ["TLSv1.2", "TLSv1.3"]

elasticsearch.hosts: ["https://es-node-1:9243", "https://es-node-2:9243"]
elasticsearch.ssl.certificateAuthorities: ["/etc/kibana/certs/ca.crt"]
elasticsearch.ssl.verificationMode: certificate
```


1.4 FIPS 140-2 Note for FedRAMP High

For FedRAMP High authorization boundaries, Elastic must run in FIPS 140-2 mode. This requires:

- Elastic Cloud for US Government region (us-gov-east-1 or us-gov-west-1) or self-managed with a FIPS-validated JVM (Azul Zulu OpenJDK FIPS Edition or Red Hat OpenJDK FIPS).
- Setting `xpack.security.fips_mode.enabled: true` in `elasticsearch.yml`. This disables algorithms that are not FIPS-approved (e.g., MD5, SHA-1, RC4).
- PKCS#12 keystores must be replaced with PEM format when FIPS mode is active because PKCS#12 uses non-FIPS algorithms by default in the Bouncy Castle provider.
- Kibana must also set `xpack.security.fips_mode.enabled: true`.
- The `xpack.security.authc.password_hashing.algorithm` must be set to `pbkdf2_stretch` or `pbkdf2` (not `bcrypt`) in FIPS mode.

```
# elasticsearch.yml – FIPS mode additions
xpack.security.fips_mode.enabled: true
xpack.security.authc.password_hashing.algorithm: pbkdf2_stretch
```

2. Authentication and SSO

2.1 Authentication Methods

Method	Use Case	Recommendation
Native (file/native realm)	Break-glass local admin accounts only	Limit to 1-2 accounts; store credentials in agency secrets manager; rotate quarterly
SAML 2.0	Primary agency user authentication via IdP (Okta, Azure AD, Ping)	Required for all human users in production
OIDC	Cloud-native IdP integration where SAML is not available	Acceptable alternative to SAML; use PKCE flow
Kerberos	On-premises Active Directory environments without federation	Use only when SAML/OIDC is not feasible; requires KDC connectivity
LDAP / Active Directory	Legacy environments; attribute-based group mapping	Avoid for new deployments; prefer SAML with AD as backend IdP
PKI (client certificates)	Service accounts, pipeline processes, Logstash	Required for non-human system accounts; certificates must be issued by agency PKI
API keys	Short-lived programmatic access (Fleet, integrations, SOAR webhook)	Rotate quarterly minimum; scope to minimum required index privileges

2.2 kibana.yml SAML Configuration

```
# kibana.yml – SAML SSO with attribute mapping to M-26-14 RBAC roles
```

```
xpack.security.authc.providers:  
  saml.saml1:  
    order: 0  
    realm: saml1  
    description: "Agency SSO"  
    icon: "logoSecurity"  
    hint: "Sign in with your agency credentials"  
    showInSelector: true  
  basic.basic1:  
    order: 1  
    description: "Local admin (break-glass only)"  
    showInSelector: false
```

```
# elasticsearch.yml – SAML realm definition
```

```
xpack.security.authc.realms.saml.saml1:  
  order: 2  
  idp.metadata.path: /etc/elasticsearch/saml/agency-idp-metadata.xml  
  idp.entity_id: "https://sso.agency.gov/saml/metadata"  
  sp.entity_id: "https://kibana.agency.gov"  
  sp.acs: "https://kibana.agency.gov/api/security/saml/callback"  
  sp.logout: "https://kibana.agency.gov/logout"  
  attributes.principal: "NameID"  
  attributes.name: "http://schemas.xmlsoap.org/ws/2005/05/identity/claims/name"  
  attributes.mail: "http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress"  
  attributes.groups: "http://schemas.xmlsoap.org/claims/Group"  
  # Map IdP groups to Elasticsearch roles via role mapping API  
  # (see /api/security/role_mapping)
```

Role mappings connect IdP group claims to Elastic roles:

```
PUT /_security/role_mapping/m2614_soc_analysts
{
  "roles": ["m2614_soc_analyst"],
  "enabled": true,
  "rules": {
    "field": {
      "groups": "CN=SOC-Analysts,OU=Security,DC=agency,DC=gov"
    }
  }
}
```

2.3 API Key Rotation

API keys used by Fleet, SOAR webhooks, and ingest pipelines must be rotated at least quarterly per M-26-14 access control guidance.

```
# Create a scoped API key for the SOAR webhook integration
curl -s -X POST "https://es-node:9243/_security/api_key" \
  -H "Content-Type: application/json" \
  -u "elastic:${ELASTIC_PASSWORD}" \
  -d '{
    "name": "soar-webhook-m2614",
    "expiration": "90d",
    "role_descriptors": {
      "soar_writer": {
        "indices": [
          {
            "names": ["logs-m2614.*", ".alerts-security.*"],
            "privileges": ["write", "create_index"]
          }
        ]
      }
    }
  }'

# Invalidate a rotated key
curl -s -X DELETE "https://es-node:9243/_security/api_key" \
  -H "Content-Type: application/json" \
  -u "elastic:${ELASTIC_PASSWORD}" \
  -d '{"name": "soar-webhook-m2614"}'
```

Store the returned `encoded` value in the agency secrets manager (HashiCorp Vault, AWS Secrets Manager, or equivalent). Never store raw API keys in environment files checked into version control.

3. RBAC Roles

3.1 Role Summary

Role Name	Permissions	Assigned To
<code>m2614_soc_analyst</code>	Read <code>.alerts-security.*</code> , <code>logs-m2614.*</code> , all dashboards; run saved searches; acknowledge alerts	SOC analysts, tier-1 and tier-2 responders
<code>m2614_compliance_officer</code>	Read all M-26-14 indices and dashboards; read ML job results; export CSV; no write	ISSO, Compliance Officer, IG audit staff
<code>m2614_security_engineer</code>	Full read/write on <code>logs-m2614.*</code> , ingest pipelines, detection rules, ML jobs; manage Fleet policies	Security engineers, detection engineers
<code>m2614_ciso_viewer</code>	Read-only across all compliance dashboards, maturity scores, alert summaries; no index-level access	CISO, Deputy CISO, CIO, IG
<code>m2614_fleet_admin</code>	Manage Fleet Server, agent policies, integrations, enrollment tokens; no direct index write	Fleet / infrastructure engineers
<code>elastic_admin</code>	Superuser — all cluster and index privileges	Break-glass only; requires MFA + audit justification

3.2 m2614_soc_analyst Role Definition

```
PUT /_security/role/m2614_soc_analyst
{
  "cluster": [],
  "indices": [
    {
      "names": [
        ".alerts-security.*",
        "logs-m2614.*",
        "logs-endpoint.*",
        "logs-network_traffic.*",
        "logs-system.*",
        "logs-windows.*",
        "logs-zeek.*"
      ],
      "privileges": ["read", "view_index_metadata"]
    },
    {
      "names": [".lists-*", ".items-*"],
      "privileges": ["read", "view_index_metadata"]
    }
  ],
  "applications": [
    {
      "application": "kibana-.kibana",
      "privileges": [
        "feature_siem.read",
        "feature_siem.minimal_read",
        "feature_securitySolutionCases.read",
        "feature_actions.read",
        "feature_alerting.read",
        "feature_ml.read",
        "feature_dashboard.read",
        "feature_discover.read",
        "feature_visualize.read"
      ],
      "resources": ["*"]
    }
  ],
  "run_as": []
}
```

3.3 m2614_compliance_officer Role Definition

```
PUT /_security/role/m2614_compliance_officer
{
  "cluster": ["monitor"],
  "indices": [
    {
      "names": [
        "logs-m2614.*",
        ".alerts-security.*",
        ".ml-anomalies-*",
        ".ml-notifications-*"
      ],
      "privileges": ["read", "view_index_metadata"]
    }
  ],
  "applications": [
    {
      "application": "kibana-.kibana",
      "privileges": [
        "feature_siem.read",
        "feature_ml.read",
        "feature_dashboard.read",
        "feature_discover.read",
        "feature_canvas.read",
        "feature_reporting.minimal_read"
      ],
      "resources": ["*"]
    }
  ],
  "run_as": []
}
```

3.4 m2614_security_engineer Role Definition

```
PUT /_security/role/m2614_security_engineer
{
  "cluster": ["monitor", "manage_ml", "manage_ingest_pipelines", "manage_ilm"],
  "indices": [
    {
      "names": ["logs-m2614.*", ".alerts-security.*"],
      "privileges": ["all"]
    },
    {
      "names": ["logs-*", "metrics-*", "traces-*"],
      "privileges": ["read", "view_index_metadata"]
    }
  ],
  "applications": [
    {
      "application": "kibana-.kibana",
      "privileges": [
        "feature_siem.all",
        "feature_ml.all",
        "feature_fleet.all",
        "feature_dashboard.all",
        "feature_discover.all",
        "feature_alerting.all",
        "feature_actions.all"
      ],
      "resources": ["*"]
    }
  ],
  "run_as": []
}
```

4. Audit Logging (Element 4)

Comprehensive audit logging is required by M-26-14 Appendix C Element 4 (Privileged Operations Monitoring). Every privileged action — index creation, role modification, API key issuance, authentication event, and detection rule change — must be captured and retained for the element4-privop-spike ML job to function correctly.

4.1 elasticsearch.yml Audit Configuration

```
# elasticsearch.yml – audit logging for all REST and transport events

xpack.security.audit.enabled: true

# Log to a dedicated index (data stream: logs-elasticsearch.audit-*)
xpack.security.audit.outputs: [index]

xpack.security.audit.logfile.events.include:
  - access_denied
  - access_granted
  - anonymous_access_denied
  - authentication_failed
  - authentication_success
  - connection_denied
  - connection_granted
  - run_as_denied
  - run_as_granted
  - security_config_change
  - tampered_request

# Exclude high-volume, low-value internal events to reduce noise
xpack.security.audit.logfile.events.exclude:
  - system_access_granted

# Capture transport layer (node-to-node) privilege escalation
xpack.security.audit.logfile.emit_node_name: true
xpack.security.audit.logfile.emit_node_host_address: true
xpack.security.audit.logfile.emit_node_host_name: true
xpack.security.audit.logfile.emit_node_id: true

# Filter to M-26-14 relevant indices (avoid auditing read noise on all logs-*)
xpack.security.audit.logfile.events.emit_request_body: false
```

4.2 kibana.yml Kibana Audit Configuration

```
# kibana.yml – Kibana-side audit logging (user actions in the UI)

xpack.security.audit.enabled: true
xpack.security.audit.appender.type: rolling-file
xpack.security.audit.appender.fileName: /var/log/kibana/audit.log
xpack.security.audit.appender.policy.type: time-interval
xpack.security.audit.appender.policy.interval: 1d
xpack.security.audit.appender.strategy.type: numeric
xpack.security.audit.appender.strategy.max: 14

# Alternatively, send directly to Elasticsearch (preferred for central retention)
# xpack.security.audit.appender.type: stream
# xpack.security.audit.appender.stream.format: json
```

Kibana audit records are indexed into `logs-kibana.audit-*` and cover: user logins, saved object access (dashboards, rules, cases), space switching, and Kibana API calls.

4.3 Audit Data Streams

Data Stream	Contents	ILM Policy
<code>logs-elasticsearch.audit-*</code>	Elasticsearch REST and transport audit events	<code>m2614-l4-hot-frozen</code> (1yr hot, 2yr frozen)
<code>logs-kibana.audit-*</code>	Kibana UI and API audit events	<code>m2614-l4-hot-frozen</code>
<code>.fleet-actions-*</code>	Fleet agent action history	<code>m2614-l3-hot-frozen</code>

4.4 element4-privop-spike ML Job

The `element4-privop-spike` ML job reads from `logs-elasticsearch.audit-*` and `logs-kibana.audit-*`, computes a baseline rate of `security_config_change` and `run_as_granted` events per hour, and raises an anomaly when the rate exceeds 3 standard deviations. This catches insider threats and compromised service accounts that begin issuing unusual numbers of privilege escalation operations.

```
// Datafeed query (simplified) – feeds element4-privop-spike
{
  "query": {
    "bool": {
      "filter": [
        { "terms": { "event.action": [
          "security_config_change",
          "run_as_granted",
          "access_denied",
          "authentication_failed"
        ]}},
        { "term": { "data_stream.dataset": "elasticsearch.audit" }}
      ]
    }
  }
}
```

5. Log Integrity (Element 5)

M-26-14 Appendix C Element 5 requires tamper-evident logs. The compliance pack implements tamper evidence via the `log-integrity-hash` ingest pipeline, which computes a SHA-256 digest of four fields for every record and stores it as `log.hash.sha256`. The `integrity_verify.py` tool and the `element5-hash-coverage` ML job provide continuous and on-demand verification respectively.

5.1 log-integrity-hash Pipeline

The pipeline is applied to all data streams that flow through the M-26-14 compliance path. It must be set as the default pipeline for the relevant index templates.

```

PUT _ingest/pipeline/log-integrity-hash
{
  "description": "M-26-14 Element 5: SHA-256 tamper-evident hash per log record",
  "processors": [
    {
      "script": {
        "description": "Compute SHA-256 of message + @timestamp + host.name + event.action",
        "lang": "painless",
        "source": """
import java.security.MessageDigest;
import java.nio.charset.StandardCharsets;

String input = (ctx.message != null ? ctx.message : '') + '|' +
                (ctx['@timestamp'] != null ? ctx['@timestamp'] : '') + '|' +
                (ctx.host != null && ctx.host.name != null ? ctx.host.name : '')
                (ctx.event != null && ctx.event.action != null ? ctx.event.action : '');

MessageDigest md = MessageDigest.getInstance('SHA-256');
byte[] digest = md.digest(input.getBytes(StandardCharsets.UTF_8));

StringBuilder sb = new StringBuilder();
for (byte b : digest) {
  sb.append(String.format('%02x', b));
}

if (ctx.log == null) { ctx.log = [:]; }
if (ctx.log.hash == null) { ctx.log.hash = [:]; }
ctx.log.hash.sha256 = sb.toString();
ctx['event.ingested_pipeline'] = 'm2614/log-integrity-hash';
        """
      }
    }
  ]
}

```

5.2 integrity_verify.py Usage

The `integrity_verify.py` tool re-computes SHA-256 hashes for records retrieved from Elasticsearch and compares them against the stored `log.hash.sha256` value. Any mismatch indicates tampering, accidental field modification, or pipeline misconfiguration.

```
# Verify all M-26-14 data streams (last 24 hours by default)
python tools/integrity_verify.py \
    --host $ES_HOST \
    --api-key $ES_API_KEY \
    --index "logs-m2614.*" \
    --since "now-24h"

# Verify a specific date range with verbose mismatch output
python tools/integrity_verify.py \
    --host $ES_HOST \
    --api-key $ES_API_KEY \
    --index "logs-m2614.hwam-default" \
    --since "2026-05-01T00:00:00Z" \
    --until "2026-05-31T23:59:59Z" \
    --verbose

# Exit codes: 0 = all hashes match, 1 = mismatches found, 2 = connection error
# Schedule via cron for daily attestation reports:
# 0 6 * * * /opt/m2614/tools/integrity_verify.py --host $ES_HOST --index "logs-m2614.*" >>
```

5.3 element5-hash-coverage ML Job

The `element5-hash-coverage` ML job monitors the percentage of newly ingested records that carry a `log.hash.sha256` field. A sudden drop in coverage (e.g., below 95%) indicates that a data stream is bypassing the ingest pipeline — either due to a misconfigured index template, a direct write by an unauthorized process, or a pipeline failure. An anomaly triggers the associated ML alert rule, which creates a case in Elastic Security.

5.4 Chain of Custody

Every log record in the compliance pack carries the following provenance fields:

Field	Value	Purpose
<code>log.hash.sha256</code>	SHA-256 hex digest	Tamper detection
<code>event.ingested</code>	ISO-8601 UTC timestamp set by Elasticsearch	Ingestion proof-of-time
<code>event.ingested_pipeline</code>	<code>m2614/log-integrity-hash</code>	Pipeline attribution
<code>host.name</code>	Originating host	Source attribution
<code>@timestamp</code>	Event time from source	Event ordering
<code>data_stream.dataset</code>	e.g., <code>m2614.hwam</code>	Data classification

This combination satisfies the THIRF (Tamper-Evident and Highly Reliable Forensic) log requirement in M-26-14 Section 3.

6. Secrets Management

All credentials used by Elasticsearch, Kibana, Fleet, Logstash, and integration scripts must be stored in secure keystores or an agency-approved secrets manager. Credentials must never appear in configuration files, environment variables exported to child processes, or version-controlled files.

6.1 Elasticsearch Keystore

```
# Add the built-in elastic user bootstrap password
elasticsearch-keystore add bootstrap.password

# Add the Kibana system user password
elasticsearch-keystore add kibana_system.password

# Add S3 snapshot repository credentials (for frozen tier)
elasticsearch-keystore add s3.client.default.access_key
elasticsearch-keystore add s3.client.default.secret_key

# Add TAXII 2.1 bearer token for CISA AIS integration
elasticsearch-keystore add xpack.fleet.outputs.cisa_ais.ssl.key_passphrase

# Verify keystore contents (values are not shown)
elasticsearch-keystore list
```

6.2 Kibana Keystore

```
# Kibana encryption keys (required for saved objects, sessions, and reporting)
kibana-keystore add xpack.encryptedSavedObjects.encryptionKey
kibana-keystore add xpack.security.encryptionKey
kibana-keystore add xpack.reporting.encryptionKey

# Kibana service account token (replaces username/password for ES connection)
kibana-keystore add elasticsearch.serviceAccountToken
```

6.3 Fleet Agent Key Management

Fleet Server automatically issues and rotates Elastic Agent enrollment tokens. Engineers should never manually create long-lived API keys for agents. The recommended pattern is:

1. Create an agent policy in Fleet for each asset tier (server, workstation, network device).
2. Fleet generates a scoped enrollment token per policy.
3. Agents enroll and receive a per-agent API key that is rotated by Fleet on the configured interval.
4. Revoke enrollment tokens for decommissioned asset tiers via Fleet UI or API.

```
# List active enrollment tokens (Fleet API)
curl -s "https://kibana.agency.gov/api/fleet/enrollment_api_keys" \
  -H "kbn-xsrf: true" \
  -H "Authorization: ApiKey ${KIBANA_API_KEY}" | jq '.items[] | {name, active, policy_id}'

# Revoke a specific enrollment token
curl -s -X DELETE "https://kibana.agency.gov/api/fleet/enrollment_api_keys/${TOKEN_ID}" \
  -H "kbn-xsrf: true" \
  -H "Authorization: ApiKey ${KIBANA_API_KEY}"
```

6.4 External Secrets Manager Integration

For Elastic Cloud deployments, Elastic Cloud on Kubernetes (ECK), or self-managed clusters, use the agency-approved secrets manager:

- **AWS Secrets Manager** — Use the `elasticsearch-keystore` with Secrets Manager CLI or the ECK `SecretProviderClass`.
- **HashiCorp Vault** — Use the Vault Agent sidecar to inject keystore values at pod startup. Set `VAULT_ADDR` and `VAULT_TOKEN` in the container environment only.
- **Azure Key Vault** — Use the Azure Workload Identity provider with ECK for AKS deployments.

7. FedRAMP High Considerations

Agencies pursuing FedRAMP High authorization for the M-26-14 Compliance Pack deployment must address the following Elastic-specific requirements in addition to standard NIST 800-53 Rev 5 controls.

7.1 FIPS Mode on Elastic Cloud for US Government

Elastic Cloud for US Government (GovCloud regions) supports FIPS 140-2 mode for Elasticsearch and Kibana. Enable it at cluster creation time in the Elastic Cloud console under **Security > FIPS mode**. This setting cannot be toggled after cluster creation without a full data migration.

Key operational impacts of FIPS mode:

- Passwords are hashed using PBKDF2 (not bcrypt). Existing bcrypt-hashed passwords must be reset after migration.
- PKCS#12 keystores are not supported. All certificates must be in PEM format.
- The `sha1` and `md5` algorithms are disabled in Painless scripts. The log-integrity-hash pipeline uses `SHA-256` and is FIPS-compliant.
- Snapshot repositories using the `repository-s3` plugin must use AWS GovCloud S3 endpoints.
- Watcher (used for SOAR webhook) uses approved TLS ciphers only.

7.2 NIST 800-53 Control Mapping

Control	Control Name	Elastic Feature	Implementation Notes
AU-2	Event Logging	Elasticsearch + Kibana audit logging	All 11 CEM categories covered by Appendix B dashboards; audit config in Section 4
AU-3	Content of Audit Records	ECS normalization via Elastic Agent integrations	All records include <code>event.action</code> , <code>user.name</code> , <code>host.name</code> , <code>@timestamp</code> , <code>source.ip</code> , <code>destination.ip</code>
AU-9	Protection of Audit Information	RBAC restricts write access to <code>logs-elasticsearch.audit-*</code> ; ILM prevents deletion during retention period	Only <code>elastic_admin</code> can delete audit indices; ILM <code>min_age</code> enforced on all M-26-14 ILM policies
AU-11	Audit Record Retention	ILM policies: <code>m2614-14-hot-frozen</code> (3 years total)	Hot tier: 1 year SSD; Frozen tier: 2 years object storage
AC-2	Account Management	SAML integration with agency IdP; RBAC role assignments	Role mappings synchronized from IdP groups; orphan accounts removed at IdP layer
AC-3	Access Enforcement	Elasticsearch RBAC; Kibana Space permissions	Field-level and document-level security available for sensitive data streams
AC-6	Least Privilege	Six named M-26-14 roles; no wildcard index privileges for non-admin roles	SOC analyst role cannot write to or delete indices
IA-2	Identification and Authentication	SAML SSO with MFA enforced at IdP; API	MFA policy is enforced at the

Control	Control Name	Elastic Feature	Implementation Notes
		keys for service accounts	agency IdP, not within Elastic
IA-3	Device Identification	Elastic Agent enrollment with Fleet policy assignment	Each agent has a unique agent ID tracked in Fleet
SC-8	Transmission Confidentiality	TLS 1.2+ on all channels; mTLS for node-to-node	Cipher suite restrictions per Section 1.2
SC-28	Protection of Information at Rest	Elasticsearch encryption at rest via Elastic Cloud or self-managed with dm-crypt/FileVault	Native Elasticsearch field-level encryption for PII fields if needed
SI-7	Software, Firmware, and Information Integrity	log-integrity-hash pipeline; <code>element5-hash-coverage</code> ML job; <code>integrity_verify.py</code>	SHA-256 per record; automated coverage monitoring; daily verification cron job

Appendix A: Security Pre-Launch Checklist

Complete all items before promoting the M-26-14 Compliance Pack to a production or Authorization to Operate (ATO) boundary.

- ☐ TLS enabled on all Elasticsearch HTTP and transport interfaces; no plain-text endpoints exposed.
- ☐ mTLS configured for Elasticsearch node-to-node communication on port 9300.
- ☐ Kibana HTTPS enabled with a certificate issued or trusted by the agency CA.
- ☐ FIPS 140-2 mode enabled if deployment is within a FedRAMP High boundary.
- ☐ Native `elastic` superuser password rotated from default and stored in agency secrets manager.
- ☐ All human users authenticated exclusively via SAML or OIDC; no password-based native realm accounts for non-break-glass users.
- ☐ All six M-26-14 RBAC roles deployed and mapped to the correct IdP groups via `role_mapping` API.
- ☐ Elasticsearch audit logging enabled and writing to `logs-elasticsearch.audit-*` data stream.
- ☐ Kibana audit logging enabled and retained for minimum 3 years under `m2614-l4-hot-frozen` ILM policy.

- ☐ `log-integrity-hash` ingest pipeline set as default pipeline on all `logs-m2614.*` index templates.
- ☐ `integrity_verify.py` scheduled as a daily cron job; output written to a tamper-evident log destination.
- ☐ All six ML jobs deployed, started, and producing anomaly scores in `.ml-anomalies-*`.
- ☐ All 13 ML alert rules enabled and connected to cases in Elastic Security.
- ☐ API keys for all integrations (SOAR webhook, CISA AIS TAXII, HWAM httpjson) scoped to minimum required privileges and expiration set to 90 days.
- ☐ Fleet enrollment tokens reviewed; any tokens for decommissioned asset tiers revoked.
- ☐ Elasticsearch and Kibana keystore values confirmed present (`elasticsearch-keystore list`); no credentials in plaintext config files.
- ☐ ILM policies applied to all data streams; verify with `GET /_data_stream/logs-m2614.*` that ILM policy name is present.
- ☐ Network access controls (security groups, firewall rules) restrict port 9300 to Elasticsearch nodes only; port 8220 to authorized Fleet Server IPs only.

Network Architecture

Network Architecture — M-26-14 Compliance Pack

Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x

Overview

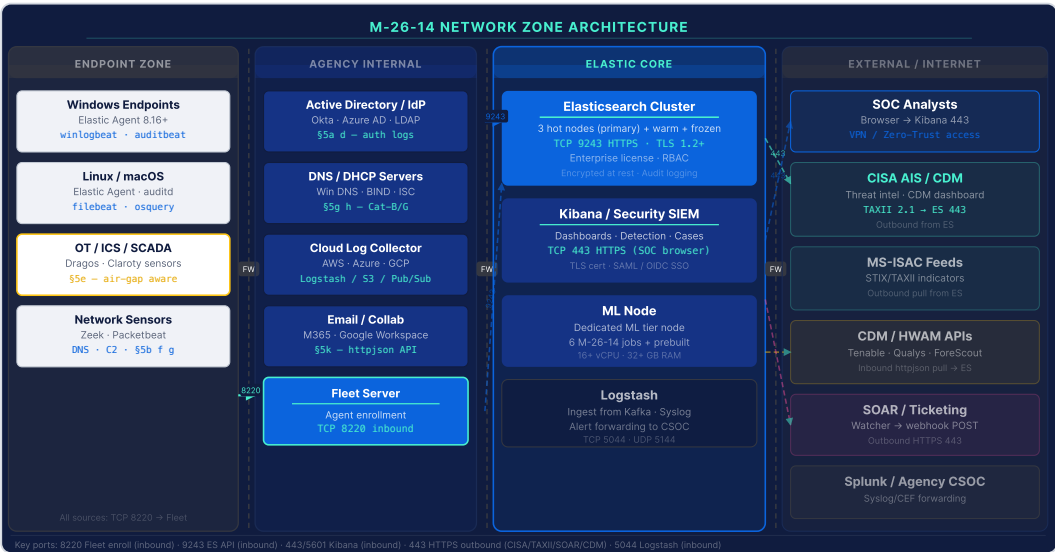
This document defines the reference network architecture for deploying the M-26-14 Compliance Pack. The design enforces four distinct trust zones with least-privilege traffic flows, mutual TLS everywhere within the Elastic Core, and encrypted transport for all cross-zone communication. No unencrypted log data traverses network boundaries. The architecture supports both on-premises federal agency deployments and FedRAMP-authorized cloud deployments on Elastic Cloud.

The four zones are:

- **Zone 1 — Endpoint:** All managed assets generating logs (workstations, servers, OT/ICS sensors, network taps)
- **Zone 2 — Agency Internal:** Directory services, DNS/DHCP, email infrastructure, cloud-native collectors, and SIEM feed aggregators
- **Zone 3 — Elastic Core:** Elasticsearch cluster, Kibana, Fleet Server, ML nodes, Logstash, and ingest pipelines
- **Zone 4 — External/Internet:** CISA AIS, CDM APIs, MS-ISAC TAXII feeds, SOAR platforms, and SOC analyst browsers accessing Kibana over the internet

Traffic between zones passes through zone-specific firewalls (FW1 through FW3). All external connectivity uses TLS 1.2 minimum; TLS 1.3 is recommended. Inter-node Elasticsearch communication uses mutual TLS (mTLS) with certificates issued from the Elastic certificate authority.

Diagram



Network Zones

1. Network Zone Model

Zone	Description	Components	Trust Level
Zone 1 — Endpoint	Managed assets and sensors generating telemetry and logs for CEM categories A–K	Windows/Linux/macOS endpoints, servers, OT/ICS devices, network sensors, syslog forwarders, Beats agents, Elastic Agents	Low–Medium
Zone 2 — Agency Internal	Core agency infrastructure providing identity, DNS, cloud services, and intermediate log aggregation	Active Directory / LDAP, IdP (Okta, Azure AD), DNS/DHCP servers, email gateways, cloud service collectors, Logstash aggregator nodes	Medium
Zone 3 — Elastic Core	Protected SIEM and log management platform; highest-trust zone for stored data and analytics	Elasticsearch cluster nodes (hot/warm/frozen), Kibana, Fleet Server, Logstash ingest nodes, ML dedicated nodes, ingest pipelines	High
Zone 4 — External/Internet	Untrusted external systems; all connections inbound or outbound are TLS-only and allowlisted by FQDN or IP	CISA AIS (TAXII 2.1 endpoint), CDM/HWAM APIs, MS-ISAC TAXII feed, SOAR webhook receiver, remote SOC analyst browsers	Untrusted — TLS only

Fleet Server Placement

Fleet Server must be reachable from Zone 1 endpoints on TCP 8220. Two accepted placements:

- Zone 2 (Agency Internal, recommended):** Fleet Server resides on the agency internal segment. Endpoint agents initiate outbound connections from Zone 1 through FW1 to Fleet Server in Zone 2. Fleet Server then forwards configuration and data to Elasticsearch in Zone 3 through FW2. This is the simplest model for a fully internal deployment.

2. **Dedicated DMZ:** For agencies with strict east-west segmentation, Fleet Server is placed in a dedicated DMZ between Zone 1 and Zone 3. FW1 permits endpoint → DMZ on 8220; FW2 permits DMZ Fleet Server → Elasticsearch on 9243. No direct Zone 1 → Zone 3 path exists.

In both placements, only Fleet Server initiates connections to Elasticsearch. Endpoints never connect directly to Elasticsearch or Kibana from Zone 1.

2. Required Ports and Protocols

2.1 Inbound to Elastic Core (Zone 3)

Source	Destination	Protocol	Port	Purpose	TLS Required
Fleet Server (Zone 2 / DMZ)	Elasticsearch (Zone 3)	HTTPS	9243	Agent enrollment, policy delivery, and data ingestion via Fleet	Yes — mTLS
Logstash (Zone 2)	Elasticsearch (Zone 3)	HTTPS	9243	Batch log forwarding from syslog aggregators, Beats → Logstash pipelines	Yes — TLS
Kibana (Zone 3 internal)	Elasticsearch (Zone 3)	HTTPS	9243	Kibana backend queries, dashboard rendering, alerting, ML job management	Yes — mTLS
ML Nodes (Zone 3 internal)	Elasticsearch (Zone 3)	HTTPS / Transport	9243 / 9300	ML job coordination, model state, datafeed queries	Yes — mTLS
Logstash Beats Input (Zone 2)	Logstash (Zone 3)	Lumberjack/TCP	5044	Beats agents forwarding through Logstash instead of Fleet	Yes — TLS

Source	Destination	Protocol	Port	Purpose	TLS Required
Syslog Forwarders (Zone 1 / 2)	Logstash (Zone 3)	TCP/UDP	5144	Legacy syslog sources: network devices, OT/ICS, appliances	TLS recommended; UDP is cleartext
SOC Analysts (Zone 4 via reverse proxy)	Kibana (Zone 3)	HTTPS	443	Kibana UI access for dashboards, investigations, and compliance attestation	Yes — TLS 1.2+
SOAR Webhook (Zone 4)	Kibana / Watcher (Zone 3)	HTTPS	443	Inbound webhook triggers for automated response actions	Yes — TLS
CDM/HWAM httpjson poller (Zone 3)	(outbound — see 2.2)	—	—	Elastic polling CDM APIs outbound; no inbound path required	N/A
Osquery Manager (Zone 3 internal)	Elasticsearch (Zone 3)	HTTPS	9243	Osquery results from Fleet-managed endpoints via osquery-normalize pipeline	Yes — mTLS
Elastic Agent (Zone 1, direct mode)	Fleet Server (Zone 2 / DMZ)	HTTPS	8220	Agent check-in, policy retrieval, and data upload to Fleet	Yes — TLS

2.2 Outbound from Elastic Core (Zone 3)

Source	Destination	Protocol	Port	Purpose	Notes
Elasticsearch / Logstash (Zone 3)	CISA AIS TAXII 2.1 (Zone 4)	HTTPS	443	Pull threat intelligence from <code>cisaservices.dhs.gov</code> TAXII endpoint	Client cert or API key; allowlist destination FQDN
Elasticsearch / Logstash (Zone 3)	MS-ISAC TAXII feed (Zone 4)	HTTPS	443	Pull STIX/TAXII bundles from MS-ISAC endpoint	OAuth2 bearer token; schedule pull every 1–4 hours
Elasticsearch httpjson input (Zone 3)	CDM/HWAM APIs (Zone 4)	HTTPS	443	Poll hardware asset data from CDM connectors (Tenable, Qualys, ForeScout, CrowdStrike)	API key per integration; 15-minute default poll interval
Kibana Watcher (Zone 3)	SOAR webhook receiver (Zone 4)	HTTPS	443	Push alert notifications to SOAR platform for automated response	HMAC signature recommended; allowlist SOAR IP/FQDN
Logstash output (Zone 3)	Splunk HEC (Zone 4 or Zone 2)	HTTPS	8088	Forward selected log streams to Splunk for agencies with dual-SIEM requirements	Splunk HEC token in Authorization header

2.3 Firewall Rule Summary

All rules are ordered. An explicit deny-all closes each ruleset.

FW1 — Zone 1 (Endpoint) to Zone 2 (Agency Internal)

```
# FW1 — Ordered allow list (all other traffic denied)
ALLOW Zone1_Endpoints → Fleet_Server_VIP TCP 8220 # Elastic Agent enrollment and
ALLOW Zone1_Endpoints → Logstash_Syslog TCP 5144 # Syslog over TLS from server
ALLOW Zone1_Beats_Agents → Logstash_Beats TCP 5044 # Beats to Logstash (legacy and
ALLOW Zone1_DNS_Clients → Agency_DNS UDP 53 # Standard DNS (internal resolvers)
DENY ALL → ALL # Default deny
```

FW2 — Zone 2 (Agency Internal) to Zone 3 (Elastic Core)

```
# FW2 — Ordered allow list (all other traffic denied)
ALLOW Fleet_Server → Elasticsearch_VIP TCP 9243 # Fleet → ES ingest and management
ALLOW Logstash_Aggregator → Elasticsearch_VIP TCP 9243 # Logstash → ES ingest
ALLOW Logstash_Aggregator → Elasticsearch_VIP TCP 9300 # Logstash → ES transport (cluster)
ALLOW Kibana_Proxy → Elasticsearch_VIP TCP 9243 # Kibana backend queries
ALLOW AD_IdP → Kibana TCP 636 # LDAPS for Kibana native repository
DENY ALL → ALL # Default deny
```

FW3 — Zone 4 (External/Internet) to Zone 3 (Elastic Core) / outbound

```
# FW3 — Inbound rules (Zone 4 → Zone 3)
ALLOW SOC_Analyst_IP_Range → Kibana_Reverse_Proxy TCP 443 # Kibana HTTPS access
ALLOW SOAR_Webhook_IP → Kibana_Reverse_Proxy TCP 443 # SOAR webhook trigger
DENY ALL → ALL # Default deny inbound

# FW3 — Outbound rules (Zone 3 → Zone 4)
ALLOW ES_Logstash_VIP → cisaservices.dhs.gov TCP 443 # CISA AIS TAXII
ALLOW ES_Logstash_VIP → taxii.msisac.org TCP 443 # MS-ISAC TAXII
ALLOW ES_Logstash_VIP → CDM_API_endpoints TCP 443 # CDM/HWAM APIs
ALLOW Kibana_Watcher → SOAR_Webhook_endpoint TCP 443 # Alert webhooks
ALLOW Logstash_VIP → Splunk_HEC_endpoint TCP 8088 # Splunk forwarding (cluster)
DENY ALL → ALL # Default deny outbound
```

3. DNS Requirements

Internal FQDNs

Register the following internal DNS A or CNAME records pointing to the appropriate VIPs or node IPs:

FQDN	Resolves To	Purpose
<code>es-hot-01.siem.agency.gov</code>	ES Hot Node 1 IP	Elasticsearch hot tier node
<code>es-hot-02.siem.agency.gov</code>	ES Hot Node 2 IP	Elasticsearch hot tier node
<code>es-warm-01.siem.agency.gov</code>	ES Warm Node 1 IP	Elasticsearch warm tier node
<code>es-frozen-01.siem.agency.gov</code>	ES Frozen Node 1 IP	Elasticsearch frozen tier node
<code>es.siem.agency.gov</code>	Elasticsearch LB VIP	Coordinating endpoint for Kibana and Logstash
<code>kibana.siem.agency.gov</code>	Kibana reverse proxy VIP	Primary SOC analyst access
<code>fleet.siem.agency.gov</code>	Fleet Server LB VIP	Elastic Agent enrollment and check-in
<code>logstash.siem.agency.gov</code>	Logstash ingest VIP	Syslog and Beats aggregation

All internal FQDNs must be resolvable from Zone 1 (for Fleet Server), Zone 2 (for Logstash), and Zone 3 (for inter-component communication). Split-horizon DNS is acceptable; do not expose internal ES node FQDNs in external DNS.

External FQDNs Required (allowlist at FW3)

FQDN	Purpose
<code>cisaservices.dhs.gov</code>	CISA AIS TAXII 2.1 endpoint
<code>taxii.msisac.org</code>	MS-ISAC TAXII threat feed
<code>*.qualys.com</code>	Qualys CDM/HWAM API (cloud variant)
<code>cloud.tenable.com</code>	Tenable.io CDM/HWAM API
<code>api.crowdstrike.com</code>	CrowdStrike CDM/HWAM API
<code>*.foreScout.com</code>	ForeScout eyeSight API (cloud variant)

Resolve these FQDNs to IPs quarterly and update FW3 ACLs. Do not use wildcard IP blocks.

Air-Gapped Environments

For classified or air-gapped deployments where outbound internet is prohibited:

1. **TAXII feeds:** Mirror STIX bundles to an internal file share or local TAXII server. Configure the Logstash TAXII input to poll the internal mirror instead of the external endpoint. Refresh the mirror via secure removable media on a schedule approved by the ISSO.
2. **CDM APIs:** If CDM connectors are internal-only (on-premises Tenable.sc, ForeScout CounterACT), point the httpjson poller to the internal API endpoint and remove the FW3 outbound rule.
3. **Elastic package updates:** Pre-download Elastic Agent integration packages and host them on an internal package registry. Set `xpack.fleet.registryUrl` in `kibana.yml` to the internal registry URL.

4. Load Balancer and Proxy

Fleet Server Load Balancer (TCP Layer 4)

Deploy an L4 load balancer in front of Fleet Server VMs for high availability:

- **Protocol:** TCP passthrough (do not terminate TLS at the LB; Fleet Server handles TLS)
- **Port:** 8220
- **Health check:** TCP connect to 8220 with a 5-second timeout; mark unhealthy after 2 consecutive failures
- **Session persistence:** Not required. Fleet Server connections are stateless; agents reconnect automatically after failover

- **Backend pool:** Minimum two Fleet Server instances for HA; scale horizontally for more than 5,000 agents

Elasticsearch Load Balancer / Coordinating Node

Two acceptable patterns for distributing Kibana and Logstash query load across the Elasticsearch cluster:

1. **Coordinating-only nodes (recommended for large clusters):** Deploy two or more ES nodes with all roles disabled (`node.roles: []`). These nodes accept requests, fan out to data nodes, and aggregate results. Kibana and Logstash point to the coordinating node VIP on 9243.
2. **L7 reverse proxy:** An nginx or HAProxy instance terminates TLS and distributes connections round-robin to all hot-tier data nodes on 9243. Simpler for small deployments but adds a TLS hop.

In either pattern, the load balancer or coordinating node VIP is what appears in `kibana.yml` (`elasticsearch.hosts`) and Logstash `elasticsearch` output config.

Kibana Reverse Proxy

Run an nginx or HAProxy reverse proxy in front of Kibana to handle external HTTPS:

```
# nginx example - Kibana reverse proxy
server {
    listen 443 ssl;
    server_name kibana.siem.agency.gov;

    ssl_certificate      /etc/nginx/certs/kibana.crt;
    ssl_certificate_key  /etc/nginx/certs/kibana.key;
    ssl_protocols       TLSv1.2 TLSv1.3;
    ssl_ciphers          HIGH:!aNULL:!MD5;

    location / {
        proxy_pass        https://127.0.0.1:5601;
        proxy_set_header  Host            $host;
        proxy_set_header  X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header  X-Forwarded-Proto $scheme;
        proxy_read_timeout 300s;
    }
}
```

Preserving `X-Forwarded-For` is required for Kibana audit logging to record the originating SOC analyst IP rather than the proxy IP. Set `server.xsrf.allowlist` in `kibana.yml` if SOAR webhooks POST to the Kibana Actions API.

5. Air-Gapped Notes

The following components require special handling in air-gapped or classified deployments:

Fleet Server

Fleet Server is the only Elastic Core component that must accept inbound connections from Zone 1. In an air-gapped deployment, this inbound path remains intact (endpoints → Fleet Server on 8220), but Fleet Server's outbound to the Elastic Package Registry (`epr.elastic.co`) is blocked.

Mitigation: Host a local package registry. Export all required integration packages from a connected staging environment and import them to the internal registry before deployment. Fleet Server itself does not need internet access once agents are enrolled and policies are distributed.

TAXII Threat Intelligence Feeds

For CISA AIS and MS-ISAC feeds when outbound HTTPS to external TAXII endpoints is prohibited:

Method	Steps
File copy of STIX bundles	Download STIX JSON bundles on a connected workstation, transfer via removable media, place in a directory watched by a Logstash <code>file</code> input with a custom ingest pipeline
Internal TAXII mirror	Deploy an open-source TAXII server (e.g., OpenTAXII) on an internal host, sync bundles via one-way data diode, configure the Elastic Threat Intelligence integration to poll the internal mirror
Manual Kibana import	Use the Kibana Security Threat Intelligence UI to manually import STIX 2.x files; acceptable for low-volume scenarios

Elastic Agent Package Updates

Set the following in `kibana.yml`:

```
xpack.fleet.registryUrl: "https://epr-internal.siem.agency.gov"
```

Point DNS for `epr-internal.siem.agency.gov` to an internal nginx server hosting a mirrored copy of `epr.elastic.co/packages`.

6. Cloud (FedRAMP) Notes

For agencies using **Elastic Cloud on AWS GovCloud** (FedRAMP High):

What Elastic Manages

Elastic Cloud handles the following automatically; no customer action is required:

- Inter-node mTLS between all Elasticsearch nodes within the cluster
- Internal load balancing for Kibana → Elasticsearch and Logstash → Elasticsearch
- Availability zone placement across AWS GovCloud AZs (us-gov-west-1 or us-gov-east-1)
- Certificate rotation for cluster-internal TLS
- Elasticsearch transport layer encryption (port 9300 not exposed externally)

Customer-Controlled Security Controls

Control	Mechanism	Notes
Source IP allowlist	Elastic Cloud IP filter (traffic filter rules)	Allowlist agency egress IPs and VPC CIDR for Elasticsearch (9243) and Kibana (443)
Outbound webhook destinations	Kibana Actions allowlist (<code>xpack.actions.allowedHosts</code>)	Add SOAR endpoint FQDNs; Elastic Cloud does not restrict outbound by default
VPC peering	AWS PrivateLink or VPC peering to agency VPC	Eliminates internet routing for Logstash → Elasticsearch; preferred for L3/L4 deployments
Encryption at rest	AWS KMS with customer-managed keys (BYOK)	Available on Enterprise tier; configure in Elastic Cloud console under Security
Audit logging	Elasticsearch audit logs to a separate cluster or S3	Required for FedRAMP AC-2, AU-9; ship to a separate logging account

Reference

See `diagrams/ra-cloud.md` for the Elastic Cloud-specific architecture diagram, including PrivateLink topology and AWS security group recommendations.

Appendix A: Full Port Reference Table

Source	Destination	Protocol	Port	Purpose	TLS	Required / Optional
Elastic Agent (Zone 1)	Fleet Server (Zone 2/DMZ)	HTTPS	8220	Agent enrollment, policy, data upload	Yes	Required
Beats Agent (Zone 1)	Logstash Beats input (Zone 3)	Lumberjack	5044	Legacy Beats → Logstash forwarding	Yes	Optional
Syslog source (Zone 1/2)	Logstash syslog input (Zone 3)	TCP	5144	Syslog over TLS from network devices	Yes	Required for Cat-B/F/G
Syslog source (legacy, Zone 1)	Logstash syslog input (Zone 3)	UDP	514	Cleartext syslog (legacy; avoid)	No	Optional — deprecated
Fleet Server (Zone 2)	Elasticsearch (Zone 3)	HTTPS	9243	Fleet data ingest and management	Yes (mTLS)	Required
Logstash (Zone 2/3)	Elasticsearch (Zone 3)	HTTPS	9243	Log ingest via Logstash pipelines	Yes	Required
Kibana (Zone 3)	Elasticsearch (Zone 3)	HTTPS	9243	Kibana backend API and queries	Yes (mTLS)	Required
ML Nodes (Zone 3)	Elasticsearch (Zone 3)	HTTPS / Transport	9243 / 9300	ML job coordination	Yes (mTLS)	Required if ML nodes dedicated
ES Nodes (Zone 3 internal)	ES Nodes (Zone 3 internal)	Transport	9300	Intra-cluster node communication	Yes (mTLS)	Required
SOC Analyst (Zone 4)	Kibana reverse	HTTPS	443	Kibana UI access	Yes (TLS)	Required

Source	Destination	Protocol	Port	Purpose	TLS	Required / Optional
	proxy (Zone 3)				1.2+)	
SOAR platform (Zone 4)	Kibana reverse proxy (Zone 3)	HTTPS	443	Webhook triggers to Kibana Actions	Yes	Optional
Kibana (Zone 3)	AD/LDAP IdP (Zone 2)	LDAPS	636	Kibana native LDAP realm	Yes	Required if LDAP auth
Kibana (Zone 3)	SAML IdP (Zone 2)	HTTPS	443	SAML SSO for Kibana	Yes	Optional (recommended)
Elasticsearch (Zone 3)	CISA AIS TAXII (Zone 4)	HTTPS	443	Threat intelligence pull	Yes	Required
Elasticsearch (Zone 3)	MS-ISAC TAXII (Zone 4)	HTTPS	443	Threat intelligence pull	Yes	Required
Elasticsearch httpjson (Zone 3)	CDM/HWAM API (Zone 4)	HTTPS	443	Asset inventory polling	Yes	Required (E1 Asset Coverage)
Kibana Watcher (Zone 3)	SOAR webhook (Zone 4)	HTTPS	443	Alert escalation	Yes	Optional
Logstash (Zone 3)	Splunk HEC (Zone 4/2)	HTTPS	8088	Dual-SIEM forwarding	Yes	Optional
Osquery (Zone 1)	Fleet Server (Zone 2)	HTTPS	8220	Osquery results via Fleet	Yes	Optional (E1 enrichment)
Elastic Package Registry poller (Zone 3)	epr.elastic.co (Zone 4)	HTTPS	443	Integration package updates	Yes	Optional (air-gap: internal mirror)

Source	Destination	Protocol	Port	Purpose	TLS	Required / Optional
Metricbeat / internal monitor (Zone 3)	Elasticsearch (Zone 3)	HTTPS	9243	Self-monitoring for cluster health	Yes	Recommended

Appendix B: FQDN Allowlist

The following FQDNs must be resolvable and reachable from Zone 3 (Elastic Core) for full compliance pack functionality.

FQDN	Purpose	Direction	Required / Optional
<code>cisaser vices.dh s.gov</code>	CISA AIS TAXII 2.1 threat intelligence	Outbound (Zone 3 → Zone 4)	Required
<code>taxii.m sisac.or g</code>	MS-ISAC TAXII 2.1 threat intelligence	Outbound (Zone 3 → Zone 4)	Required
<code>cloud.t enable.c om</code>	Tenable.io CDM/HWAM API	Outbound (Zone 3 → Zone 4)	Required if Tenable used
<code>*.qualy s.com</code>	Qualys CDM/HWAM API (cloud)	Outbound (Zone 3 → Zone 4)	Required if Qualys used
<code>api.cro wdstrike .com</code>	CrowdStrike Falcon CDM API	Outbound (Zone 3 → Zone 4)	Required if CrowdStrike used
<code>*.fores cout.co m</code>	ForeScout eyeSight cloud API	Outbound (Zone 3 → Zone 4)	Required if ForeScout cloud used
<code>epr.ela stic.co</code>	Elastic Package Registry (integration updates)	Outbound (Zone 3 → Zone 4)	Optional (use internal mirror for air-gap)
<code>artifac ts.elast ic.co</code>	Elastic Agent binary and package downloads	Outbound (Zone 3 → Zone 4)	Optional (use internal mirror for air-gap)
<code>kibana. siem.age ncy.gov</code>	Kibana reverse proxy — SOC analyst access	Inbound (Zone 4 → Zone 3)	Required
<code>fleet.s iem agen cy.gov</code>	Fleet Server VIP — Elastic Agent enrollment	Inbound (Zone 1 → Zone 2/3)	Required
<code>es.siem .agency.</code>	Elasticsearch coordinating	Internal (Zone 3)	Required

FQDN	Purpose	Direction	Required / Optional
gov	VIP		
soar.agency.gov (example)	SOAR webhook receiver — alert escalation	Outbound (Zone 3 → Zone 4)	Optional
splunk-hec.agency.gov (example)	Splunk HEC — dual-SIEM forwarding	Outbound (Zone 3 → Zone 4/2)	Optional

Sizing and Capacity

Sizing and Capacity — M-26-14 Compliance Pack

Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x

Overview

This reference architecture document provides sizing guidance for deploying the M-26-14 Compliance Pack. Actual resource consumption depends on four primary variables:

- **Endpoint count:** total managed hosts emitting logs via Elastic Agent
- **Events per second (EPS):** aggregate ingest rate across all log sources
- **Retention tier:** L3 agencies require searchable ≥ 12 months and retrievable ≥ 30 months; L4 agencies (high-risk, CISA-designated) require searchable ≥ 24 months and retrievable ≥ 48 months. Agencies must confirm their exact thresholds against M-26-14 Appendix C for their assigned tier.
- **ML load:** 6 custom ML jobs plus up to 13 associated alert rules; prebuilt UEBA jobs add significant memory overhead when enabled

All storage estimates in this document use ECS-normalized log data at 1–3 KB average event size. Frozen tier estimates apply searchable snapshot compression (3–5x reduction vs. raw indexed size). Figures are planning baselines — instrument your own environment for 30 days before finalizing procurement.

1. Sizing Variables

1.1 Estimated EPS by Source

Source	Per Endpoint (low)	Per Endpoint (high)	Notes
Windows endpoint (Elastic Agent)	10	50	Sysmon enabled pushes toward 50+
Windows endpoint (heavy audit policy)	30	100	Required for M-26-14 Appendix B Cat-C (account logon)
Linux endpoint (Elastic Agent)	5	20	auditd ruleset size drives variance
Network device (syslog/SNMP)	variable	variable	Firewall deny logs can dominate; sample before sizing
DNS (Zeek or DNS integration)	50/1,000 queries	200/1,000 queries	zeek.dns enrichment adds ~1.5x event size
EDR/XDR forwarding	10	40	Depends on alert volume and full telemetry toggle
Cloud audit logs (AWS CloudTrail, Azure)	5	30	API-heavy workloads spike to 100+

Rule of thumb: For a mixed enterprise environment, assume 20–40 EPS per managed endpoint when Sysmon or equivalent endpoint telemetry is active.

1.2 Daily GB Formula

$$\text{daily_GB} = \text{EPS} \times \text{avg_event_KB} \times 86400 / 1,000,000$$

Where `avg_event_KB` is the average post-ECS-normalization event size in kilobytes (use 1.5 KB for baseline planning with ECS security logs; 2–3 KB for enriched events with GeoIP, threat intel, and process ancestry fields).

Example: $3,000 \text{ EPS} \times 1.5 \text{ KB} \times 86,400 / 1,000,000 = \sim 389 \text{ GB/day}$ (before compression)

1.3 Estimated Daily Ingest Volume by Agency Scale

Endpoints	Avg EPS	avg_event_KB	Raw GB/day	Indexed GB/day (after ~30% ES overhead)
1,000	500	1.5	65	85
2,000	1,000	1.5	130	170
5,000	2,500	1.5	324	420
10,000	4,000	2.0	691	900
20,000	8,000	2.0	1,382	1,800
50,000	20,000	2.0	3,456	4,500

1.4 Storage Estimates by Retention Tier

The following table shows **total storage required** (indexed hot + searchable snapshot frozen) at each agency tier. Frozen estimates assume 4x compression from searchable snapshots stored in object storage (S3 GovCloud or Azure Government Blob).

Agency Scale	Daily GB	L3 Hot (12 mo)	L3 Frozen (18 mo delta)	L4 Hot (24 mo)	L4 Frozen (24 mo delta)
1,000 endpoints	85 GB	~1.0 TB	~1.1 TB	~2.0 TB	~2.3 TB
5,000 endpoints	420 GB	~4.9 TB	~5.7 TB	~9.8 TB	~11.4 TB
10,000 endpoints	900 GB	~10.5 TB	~12.2 TB	~21 TB	~24 TB
20,000 endpoints	1,800 GB	~21 TB	~24 TB	~42 TB	~49 TB
50,000 endpoints	4,500 GB	~52 TB	~61 TB	~105 TB	~122 TB

Notes: - "Hot" storage is NVMe or SSD-backed, required for sub-second query latency on active detections and dashboards. - "Frozen" storage uses object storage (S3, Azure Blob, GCS). Searchable snapshots allow direct querying without fully restoring data. Queries on frozen data take 10–60 seconds depending on partition and cache warming. - Add 20% buffer to all estimates for index overhead,

segment merging, and M-26-14 integrity hash fields (`log.hash.sha256` written by the `log-integrity-hash` ingest pipeline).

1.5 ML Node Sizing Note

The 6 custom M-26-14 ML jobs and 13 associated alert rules run continuously. Do not co-locate ML inference with data node roles in production. Dedicate at least one node with sufficient RAM headroom. See Section 6 for per-job memory estimates.

2. Minimum Viable (Lab / POC — Not Production)

This configuration is suitable for demonstrations, integration testing, and pack validation only. It provides no high availability, no Frozen tier, and cannot sustain production EPS loads.

Component	Spec	Notes
Elasticsearch (all-in-one)	8 vCPU, 32 GB RAM, 500 GB NVMe	Single node, all roles including ML
Kibana	4 vCPU, 8 GB RAM, 100 GB disk	Co-locate on same host or separate VM
Fleet Server	2 vCPU, 4 GB RAM	Can run as Elastic Agent policy on the same host

Limitations: - No fault tolerance — any node failure halts SIEM operations - Maximum sustainable EPS: ~500 (higher rates cause index queue pressure) - No Frozen tier: ILM policies will delete data at hot rollover rather than transitioning to frozen - ML jobs share JVM heap with data and master roles; expect resource contention - Not suitable for M-26-14 production attestation — retention and integrity requirements cannot be met - Disable `xpack.ml.max_model_memory_limit` enforcement is required on a single-node cluster to run all 6 custom ML jobs within available RAM

3. Small Agency (< 2,000 Endpoints, ~500–1,000 EPS)

Target: FISMA Moderate agency with 500–2,000 managed endpoints. Daily ingest ~130–170 GB/day. L3 or L4 retention requirement.

3.1 Node Layout

Role	Count	vCPU	RAM	Local Storage	Notes
Master-eligible (dedicated)	3	4	16 GB	200 GB SSD	Quorum requires odd count; no data roles
Hot data node	3	16	64 GB	4 TB NVMe each	Primary shard replicas across all three
Warm data node	1	8	32 GB	8 TB HDD or SSD	Compressed indices, reduced search overhead
Frozen (snapshot cache)	1	8	16 GB	500 GB SSD cache	Mounts searchable snapshots from object storage
ML node (dedicated)	1	16	32 GB	500 GB SSD	Runs all 6 custom ML jobs
Kibana	1	8	16 GB	200 GB SSD	Include task manager; increase heap to 4 GB
Fleet Server	2	4	8 GB	200 GB SSD	HA pair; load-balanced via NLB on port 8220
Coordinating (optional)	1	8	16 GB	100 GB	Offloads aggregation; add when

Role	Count	vCPU	RAM	Local Storage	Notes
					dashboards slow

Total nodes: 12–13 (excluding object storage)

3.2 Storage Estimates

- Ingest rate: ~170 GB/day indexed
- **L3:** Hot ~2.0 TB (12 months) + Frozen ~2.2 TB object storage (18-month delta to 30-month retrieval)
- **L4:** Hot ~4.1 TB (24 months) + Frozen ~4.6 TB object storage (24-month delta to 48-month retrieval)
- Object storage cost is significantly lower than NVMe — route ILM to Frozen at 30 days of hot age to minimize hot storage expenditure

3.3 AWS GovCloud Instance Recommendations

Role	Instance Type	vCPU	RAM	Storage
Master-eligible	r5.xlarge	4	32 GB	200 GB gp3 EBS
Hot data	r5.2xlarge	8	64 GB	2× 1.9 TB NVMe (i3.2xlarge) or 4 TB io2 EBS
Warm data	r5.xlarge	4	32 GB	8 TB st1 EBS
Frozen	r5.large	2	16 GB	500 GB gp3 EBS + S3 GovCloud
ML	c5.4xlarge	16	32 GB	500 GB gp3 EBS
Kibana	t3.2xlarge	8	32 GB	200 GB gp3 EBS
Fleet Server	t3.xlarge	4	16 GB	200 GB gp3 EBS

Recommended S3 buckets: `us-gov-west-1` or `us-gov-east-1` with SSE-KMS. Assign the Elasticsearch IAM role with `s3:GetObject`, `s3:PutObject`, `s3:ListBucket` scoped to the snapshot repository bucket.

3.4 Azure Government Equivalents

Role	VM Size	vCPU	RAM
Master-eligible	Standard_E4s_v3	4	32 GB
Hot data	Standard_E16s_v3	16	128 GB
Warm data	Standard_E8s_v3	8	64 GB
Frozen	Standard_D4s_v3	4	16 GB
ML	Standard_F16s_v2	16	32 GB
Kibana	Standard_D4s_v3	4	16 GB
Fleet Server	Standard_D2s_v3	2	8 GB

Azure Government regions: `usgovvirginia`, `usgovtexas`. Use Azure Blob Storage (Government) for frozen snapshots. Assign Managed Identity with Storage Blob Data Contributor on the snapshot container.

4. Medium Agency (2,000–20,000 Endpoints, ~1,000–5,000 EPS)

Target: FISMA High or high-value asset agency. Daily ingest ~420–900 GB/day. Most agencies in this band will be L4 (CISA-designated high-risk).

4.1 Node Layout

Role	Count	vCPU	RAM	Local Storage	Notes
Master-eligible (dedicated)	3	8	32 GB	500 GB SSD	Cross-AZ deployment; odd count for quorum
Hot data node	6–9	32	128 GB	8 TB NVMe each	Scale horizontally before vertically
Warm data node	3	16	64 GB	16 TB HDD/SSD	One per AZ
Frozen (snapshot cache)	2	8	32 GB	1 TB SSD cache	Active query cache; pairs with object storage
Ingest node (dedicated)	2	16	32 GB	500 GB SSD	Runs ingest pipelines: log-integrity-hash, alert-category-pipeline, osquery-normalize
Coordinating node	2	16	32 GB	500 GB SSD	Dashboard aggregations; separates search from ingest
ML node (dedicated)	2	32	64 GB	1 TB SSD	Redundancy for ML; run prebuilt UEBA jobs here
Kibana	2	16	32 GB	500 GB SSD	Load-balanced; dedicated task

Role	Count	vCPU	RAM	Local Storage	Notes
					manager instance recommended
Fleet Server	3	8	16 GB	500 GB SSD	One per AZ; NLB on port 8220

Total nodes: 26–32 (excluding object storage)

4.2 Storage Estimates

- Ingest rate: ~900 GB/day indexed (10,000–endpoint midpoint)
- **L3:** Hot ~10.5 TB (12 months) + Frozen ~12 TB object storage
- **L4:** Hot ~21 TB (24 months) + Frozen ~25 TB object storage
- At 3,000 EPS, the `log-integrity-hash` pipeline writing SHA-256 to `log.hash.sha256` adds approximately 3–5% index size overhead; budget accordingly

4.3 Cloud Instance Recommendations

Role	AWS GovCloud	Azure Government
Hot data	i3en.3xlarge (8 vCPU, 96 GB, 7.5 TB NVMe)	Standard_L16s_v2
Warm data	r5.4xlarge + 16 TB st1	Standard_E16s_v3 + Ultra Disk
Ingest	c5.4xlarge	Standard_F16s_v2
Coordinating	r5.4xlarge	Standard_E16s_v3
ML	c5.9xlarge (36 vCPU, 72 GB)	Standard_F32s_v2
Kibana	r5.2xlarge	Standard_E8s_v3
Fleet Server	r5.xlarge	Standard_D4s_v3

4.4 Three-AZ High Availability

Deploy hot data nodes in groups of 3 across three availability zones (AZ-a, AZ-b, AZ-c). Set `index.routing.allocation.awareness.attributes: zone` with corresponding `node.attr.zone` labels on each data node. Configure `cluster.routing.allocation.awareness.force.zone.values` to prevent

shard imbalance during AZ recovery. Fleet Servers should be one per AZ behind a Network Load Balancer to avoid enrollment disruption during an AZ event.

5. Large Agency (20,000+ Endpoints, 10,000+ EPS)

Target: CFO Act agency, intelligence community adjacent, or CISA-designated critical infrastructure operator. Daily ingest 1.8–4.5 TB/day. Almost certainly L4.

5.1 Node Layout

Role	Count	vCPU	RAM	Local Storage	Notes
Master-eligible (dedicated)	3	8	32 GB	500 GB SSD	Never co-locate master + data at this scale
Hot data node	15+	32–64	256 GB	8–16 TB NVMe	Increase count before RAM; target 30–50 GB shard size
Warm data node	5+	16	64 GB	32 TB HDD	Segment merging is the bottleneck; allocate CPU accordingly
Frozen (snapshot cache)	3+	16	64 GB	2 TB SSD cache	Each node mounts partitions from object storage
Ingest node	4–6	32	64 GB	1 TB SSD	Pipeline throughput is the ingest bottleneck at 10K+ EPS
Coordinating node	4–6	32	128 GB	1 TB SSD	Deep aggregations for compliance dashboards need RAM
ML node	3	32	128 GB	2 TB SSD	Prebuilt UEBA models at this scale

Role	Count	vCPU	RAM	Local Storage	Notes
					consume 2–8 GB each
Kibana	3–4	16	64 GB	500 GB SSD	Dedicated task manager node for alerting latency isolation
Fleet Server	6+	8	32 GB	500 GB SSD	Two per AZ minimum; plan for 50,000 Agent check-ins
Logstash (optional)	4	16	32 GB	500 GB SSD	Splunk forwarding (HEC), syslog on 5144, Beats on 5044

Total nodes: 50–70+ depending on ingest topology

5.2 Storage Estimates

- Ingest rate: ~3 TB/day indexed (50,000-endpoint estimate)
- **L3:** Hot ~37 TB (12 months) + Frozen ~43 TB object storage
- **L4:** Hot ~74 TB (24 months) + Frozen ~86 TB object storage
- At this scale, a dedicated S3 bucket per data stream (`logs-m2614.hwam-default`, `.alerts-security.*`) is recommended to isolate ILM lifecycle and access policy

5.3 Autoscaling on Elastic Cloud

Elastic Cloud (ECE on Elastic Cloud for Government or ESS FedRAMP) supports autoscaling for hot and ML tiers. Configure autoscaling policies with: - **Hot tier:** scale up when `es_index_latency_p99` exceeds 500 ms or JVM heap sustained above 75% - **ML tier:** scale up when `ml_job_memory_usage` exceeds 85% of `xpack.ml.max_model_memory_limit` - Set minimum and maximum bounds aligned to the storage estimates in Section 5.2 to avoid unbounded cost growth

At 10,000+ EPS, submit a support case to Elastic Federal team before deployment to review topology and FedRAMP boundary applicability.

6. ML Node Sizing

6.1 Minimum Dedicated ML Node

Parameter	Minimum	Recommended
vCPU	16	32
RAM	32 GB	64 GB
Storage	500 GB SSD	1 TB SSD
Network	10 Gbps	25 Gbps

Never assign data, ingest, or coordinating roles to the ML node in production. Set `node.roles: [ ml, remote_cluster_client ]` only.

6.2 Memory Per ML Job

Job ID	Type	Estimated Memory	Notes
<code>element1-asset-coverage</code>	Custom (anomaly detection)	10–20 MB	Counts unique asset identifiers per time bucket
<code>element2-ingestion-rate</code>	Custom (anomaly detection)	10–20 MB	Monitors EPS variance by source category
<code>element3-rule-silence</code>	Custom (anomaly detection)	15–25 MB	Detects detection rules with no recent alerts
<code>element4-privop-spike</code>	Custom (anomaly detection)	20–40 MB	Spike detection on privileged operation counts
<code>element5-hash-coverage</code>	Custom (anomaly detection)	15–30 MB	Coverage of <code>log.hash.sha256</code> field population
<code>catb-dns-entropy</code>	Custom (anomaly detection)	20–50 MB	High-cardinality DNS entropy; scales with unique FQDNs
Prebuilt UEBA (if enabled)	Prebuilt (inference)	100–500 MB each	Lateral movement, rare process — check ML job docs

Total custom jobs: approximately 90–185 MB under normal load.

Total with all prebuilt UEBA: can reach 2–4 GB depending on which prebuilt jobs are activated.

6.3 `xpack.ml.max_model_memory_limit`

Set this cluster-level setting to at least 512 MB for the custom M-26-14 jobs:

```
# elasticsearch.yml on ML node
xpack.ml.max_model_memory_limit: 2gb
xpack.ml.max_open_jobs: 30
```

For deployments running prebuilt UEBA alongside custom M-26-14 jobs, set

`xpack.ml.max_model_memory_limit: 8gb` on a 64 GB RAM ML node to leave headroom for concurrent model evaluations. Monitor with `GET _ml/memory/_stats` and the Kibana ML overview page.

7. ILM Policy Configuration

The pack ships two ILM policies. Both use a 50 GB max shard target on the hot phase to balance query performance with segment overhead.

7.1 m2614-l3-hot-frozen

For agencies with L3 retention: searchable $\geq$ 12 months, retrievable $\geq$ 30 months.

```

{
  "policy": {
    "phases": {
      "hot": {
        "min_age": "0ms",
        "actions": {
          "rollover": {
            "max_primary_shard_size": "50gb",
            "max_age": "7d"
          },
          "set_priority": { "priority": 100 }
        }
      },
      "warm": {
        "min_age": "30d",
        "actions": {
          "shrink": { "number_of_shards": 1 },
          "forcemerge": { "max_num_segments": 1 },
          "set_priority": { "priority": 50 }
        }
      },
      "cold": {
        "min_age": "90d",
        "actions": {
          "searchable_snapshot": {
            "snapshot_repository": "m2614-frozen-repo"
          },
          "set_priority": { "priority": 0 }
        }
      },
      "frozen": {
        "min_age": "12m",
        "actions": {
          "searchable_snapshot": {
            "snapshot_repository": "m2614-frozen-repo"
          }
        }
      },
      "delete": {
        "min_age": "30m",
        "actions": {
          "delete": {}
        }
      }
    }
  }
}

```



```

    }
  }
}
}

```

Note: The `delete` phase `min_age` of `30m` means 30 months from index creation. Confirm this aligns with your agency's M-26-14 Appendix C attestation before applying.

7.2 m2614-l4-hot-frozen

For agencies with L4 retention: searchable $\geq$ 24 months, retrievable $\geq$ 48 months. Same structure as L3 with extended phase ages:

Phase	L3 Transition Age	L4 Transition Age
Hot rollover	7 days or 50 GB	7 days or 50 GB
Warm transition	30 days	30 days
Cold / searchable snapshot	90 days	90 days
Frozen (full snapshot)	12 months	24 months
Delete	30 months	48 months

7.3 Rollover Guidance

The 50 GB max primary shard size is chosen to: - Keep individual shard query latency below 500 ms p95 for most compliance dashboard queries - Allow segment merges to complete within a 7-day hot window before warm transition - Avoid the query degradation seen in shards exceeding 80–100 GB with high-cardinality `agent.id` and `event.category` field aggregations

Do not increase the rollover threshold above 100 GB without profiling your specific query workload against the 7 dashboards shipped with this pack.

8. Elastic Cloud for US Government

8.1 Available Regions

Cloud Provider	Region Name	FedRAMP Status
AWS GovCloud	<code>us-gov-west-1</code> (Oregon)	FedRAMP High ATO
AWS GovCloud	<code>us-gov-east-1</code> (Virginia)	FedRAMP High ATO
Azure Government	<code>usgovvirginia</code>	FedRAMP High ATO
Azure Government	<code>usgovtexas</code>	FedRAMP High ATO

Elastic Cloud on these regions operates within the FedRAMP High boundary. Agencies can inherit security controls documented in Elastic's System Security Plan (SSP), reducing the assessment burden for M-26-14 THIRF and CEM attestation controls related to infrastructure security.

8.2 FedRAMP High ATO Benefits

Deploying on Elastic Cloud Government regions provides direct inheritance for the following M-26-14 adjacent FISMA controls: - **SI-7 (Software and Information Integrity)**: Elastic Cloud infrastructure integrity monitoring is inherited; agencies still must implement `log.hash.sha256` at the application layer via the `log-integrity-hash` ingest pipeline - **AU-9 (Protection of Audit Information)**: Object storage encryption (SSE-KMS) and access logging are inherited - **SC-28 (Protection of Information at Rest)**: Encryption at rest for hot and frozen tiers is inherited - **CP-9 (System Backup)**: Snapshot scheduling and replication to secondary regions can be inherited with appropriate configuration

Agencies must still configure and operate the M-26-14 Compliance Pack components (detection rules, ML jobs, dashboards, ILM policies) and attest to the Appendix C maturity elements — inheritance covers infrastructure, not application-layer compliance.

8.3 Capacity Buffer Recommendation

Add a 20% buffer to all node counts and storage estimates when deploying on Elastic Cloud Government to account for: - Autoscaling reaction time during ingest spikes (CISA threat advisory feeds, incident response surges) - Cross-region replication overhead if using a secondary region for disaster recovery - FedRAMP boundary audit log overhead (approximately 3–8% additional event volume from Elastic Cloud infrastructure audit logs forwarded to your cluster) - Headroom for enabling additional prebuilt UEBA ML jobs during an active threat hunt

Appendix A: Quick Reference

Agency Size	Endpoints	EPS	Daily GB	Hot Nodes	RAM/Node	Hot Storage	Frozen Storage
Lab/POC	< 500	< 500	< 65	1 (all-in-one)	32 GB	500 GB	None
Small (L3)	< 2,000	~1,000	~170	3	64 GB	2 TB	2.2 TB
Small (L4)	< 2,000	~1,000	~170	3	64 GB	4 TB	4.6 TB
Medium (L3)	2,000–20,000	~3,000	~390	6–9	128 GB	10.5 TB	12 TB
Medium (L4)	2,000–20,000	~3,000	~390	6–9	128 GB	21 TB	25 TB
Large (L3)	20,000–50,000	~10,000	~1,800	15+	256 GB	21 TB	24 TB
Large (L4)	20,000–50,000	~10,000	~1,800	15+	256 GB	42 TB	49 TB
Enterprise (L4)	50,000+	20,000+	~4,500	30+	256 GB	105 TB	122 TB

All storage figures include a 20% overhead buffer. Frozen storage is object storage (S3/Blob), not NVMe. Hot storage is NVMe or io2 EBS equivalent.

Appendix B: Cost Guidance

TCO Components

Hot Nodes (NVMe — highest cost per GB)

NVMe-backed hot data nodes are the dominant cost driver. A 3-node hot tier with 8 TB NVMe each on `i3en.3xlarge` in AWS GovCloud (on-demand) runs approximately \$3,000–5,000/month before reserved instance discounts. Enterprise License cost is separate and should be quoted through Elastic Federal Sales. At medium to large agency scale, negotiate a 3-year commit for 30–40% savings on Elastic Cloud.

Frozen Tier (object storage — lowest cost per GB)

Searchable snapshots on S3 GovCloud Standard cost approximately \$0.023/GB/month. A 25 TB frozen tier for a medium L4 agency costs approximately \$575/month in storage (query egress and API calls are

additional). Migrating data from hot to frozen aggressively (at 30 days of hot age rather than 90) can reduce NVMe requirements by 60–70% with a modest query latency trade-off for historical investigations.

ML Node

One dedicated ML node (`c5.9xlarge` or equivalent) runs approximately \$1,200–1,800/month on-demand in AWS GovCloud. At small-agency scale, the ML node is often the second-largest cost driver after hot storage. Reserved instances or Elastic Cloud autoscaling with scale-to-zero for ML nodes (when supported) reduces this cost.

Fleet Server

Fleet Server nodes are lightweight relative to data nodes. Two `t3.xlarge` instances for a small agency cost approximately \$300–400/month. At large-agency scale with 50,000 enrolled agents, plan for 6 Fleet Server nodes and approximately \$1,500/month in Fleet infrastructure cost.

Kibana

Kibana nodes are modest in cost. One to two `r5.2xlarge` instances cover most agency scales below 20,000 endpoints. At large scale, a dedicated Kibana task manager instance for alerting evaluation is recommended and adds approximately \$400–600/month.

Summary Cost Levers

Lever	Cost Impact	Trade-off
Aggressive hot-to-frozen ILM (30-day hot)	-40 to -60% storage cost	Slower historical queries
Reserved instances / 3-year commit	-30 to -40% compute cost	Upfront commitment
Elastic Cloud autoscaling ML scale-to-zero	-20 to -50% ML cost	ML job restart latency
Secondary region replication	+15 to +25% total cost	DR / AU-9 compliance
Enabling prebuilt UEBA ML jobs	+20 to +40% ML node cost	Improved threat detection

Contact Elastic Federal Sales for agency-specific TCO modeling and FedRAMP ATO documentation packages.

Operational Model

Operational Model — M-26-14 Compliance Pack

Last updated: June 2026 | Pack: 0.1.0 | Elastic: 8.16+ / 9.x

Overview

OMB Memorandum M-26-14 (May 22, 2026) supersedes M-21-31 and shifts federal agency obligations from passive log collection to **active detection, response, and attestation**. Compliance is not achieved by ingesting logs; it requires a functioning operational loop: detect anomalies, triage alerts, notify CISA where required, document gaps in POA&Ms, and attest maturity scores quarterly.

This document defines the operational model that agencies must maintain once the M-26-14 Compliance Pack is deployed. It covers four core processes:

1. **SOC Alert Triage** — daily workflow for the 39 custom detection rules and 13 ML alert rules
2. **CISA Notification** — which incidents require reporting, SLAs, and automation hooks
3. **POA&M Management** — gap detection, remediation tracking, and quarterly submission
4. **Quarterly Compliance Review** — maturity scoring, trend analysis, and formal reporting

Supporting sections cover ML job operations, ILM/retention compliance, and detection rule maintenance. Appendix A provides a complete Cat-B runbook. Appendix B is the alert category quick reference.

Minimum staffing assumptions: one Security Engineer owning the pack configuration; one or more SOC Analysts handling triage; one ISSO/Compliance Officer owning POA&M and quarterly reporting; CISO or designee signing off quarterly submissions.

1. SOC Alert Triage Workflow

1.1 Alert Queue

Open Kibana Security → **Alerts**. Apply the saved filter `m2614.category: *` to isolate M-26-14 alerts from the general alert stream. The field `m2614.category` is populated by the `alert-category-pipeline` ingest pipeline and carries values Cat-A through Cat-K corresponding to Appendix B of M-26-14.

Secondary filter columns to enable in the alerts table:

- `m2614.category`
- `host.name`

- `user.name`
- `signal.rule.name`
- `kibana.alert.risk_score`

Save this view as a shared Kibana space so all SOC analysts start from the same baseline.

1.2 Priority Order

Not all alert categories carry equal urgency. Work the queue in the following priority order:

Priority	Category	Description	Response Window
P1	Cat-B	Command and control / C2 beaconing	1 hour
P1	Cat-E	Operational technology / ICS critical	1 hour
P2	Cat-H	Off-hours privileged access	4 hours
P2	Cat-J	Data exfiltration indicators	4 hours
P2	Cat-K	Malware execution / lateral movement	4 hours
P3	Cat-A, Cat-C, Cat-D, Cat-F, Cat-G, Cat-I	All other categories	24 hours

Cat-B and Cat-E receive P1 status because they represent active adversary control of agency infrastructure or critical OT systems — scenarios where every minute of dwell time increases scope and recovery cost.

1.3 Triage Workflow

The following seven-step workflow applies to every M-26-14 alert. Deviations must be documented in the associated Kibana Case.

1. **Alert arrives** — confirm the `m2614.category` field is populated. If the field is absent, the event bypassed the `alert-category-pipeline`; route to the Security Engineer for pipeline inspection before proceeding.

2. **Cat-B or Cat-E detected** — immediately escalate to P1. Notify the on-call security lead via the SOAR webhook (Watcher action `m2614-notify-soar`). Do not wait for full investigation before escalation; escalate, then investigate in parallel.
3. **Cat-H, Cat-J, or Cat-K detected** — assign P2. Begin investigation within 4 hours. Check correlated events: for Cat-H look at `auditd` and Windows Event Log 4624/4648; for Cat-J look at `network.bytes` anomalies in `zeek.conn`; for Cat-K look at process lineage and hash coverage (`log.hash.sha256`).
4. **All other categories** — assign P3. Investigate within 24 hours. Use the **Alert Coverage by Category** dashboard to confirm this alert is not part of a larger pattern across the same asset or user.
5. **True positive determination** — open a Kibana Case (see Section 1.4 for required fields). If the incident meets CISA notification criteria (Section 2.1), initiate notification immediately. Begin containment per relevant playbook.
6. **False positive determination** — create an exception entry in the detection rule (Kibana Security → Rules → Exceptions). Do not disable the rule. Document the exception rationale and the originating alert in the Kibana Case with disposition `False Positive`. See Section 7 for false positive management guidance.
7. **Close with disposition** — every alert must close with one of three dispositions: `True Positive`, `False Positive`, or `Benign Positive` (expected behavior, not malicious but confirmed). Record the disposition in the Kibana Case. Link the case to the alert using the Cases widget in the alert detail panel.

1.4 Kibana Cases — Required Fields

Every M-26-14 alert that reaches step 5, 6, or 7 above must have an associated Kibana Case. The following fields are required; without them the case cannot be counted as evidence for Appendix C maturity attestation.

Field	Value Format	Notes
<code>m2614.category</code>	Cat-A through Cat-K	Copy from alert
Affected Asset	FQDN or IP	From <code>host.name</code> or <code>host.ip</code>
Affected User	UPN or account	From <code>user.name</code> or <code>user.principal</code>
Disposition	True Positive / False Positive / Benign Positive	Required on close
CISA Notification Status	Not Required / Pending / Submitted / Acknowledged	Update as status changes
Evidence Links	URLs to alert, timeline, relevant indices	Minimum: alert ID and index

1.5 Dashboard Reference for SOC

Dashboard	Primary User	Primary Use Case
Compliance Attestation	ISSO / Compliance Officer	Element maturity scores and attestation status
Alert Coverage by Category	SOC Analyst	Volume and trend by Cat-A through Cat-K
Asset Coverage	SOC Analyst	Which hosts are reporting and which are silent

2. CISA Notification Requirements

2.1 Notification Triggers

The following incident types require notification to CISA under M-26-14. “Confirmed” means a true positive determination has been made (Step 5 of the triage workflow above).

- Confirmed APT attribution or nation-state TTP alignment (MITRE ATT&CK groups G0001–G1050 with high confidence)
- C2 beaconing to a known-bad indicator (threat intel match via CISA AIS or MS-ISAC feeds)
- Confirmed data exfiltration (Cat-J true positive with evidence of data leaving the enclave)
- OT/ICS incident (Cat-E true positive affecting operational technology or industrial control systems)

- Mass file operations on sensitive systems (Cat-J variant: bulk read/copy/encrypt of files classified or marked CUI)
- Ransomware execution confirmed (Cat-K with encryption behavior and ransom indicator)

If uncertain whether an incident meets the threshold, consult the CISA US-CERT Incident Reporting System guidance. When in doubt, report — the cost of under-reporting exceeds the cost of a precautionary report.

2.2 Notification SLA Table

Incident Type	SLA	Channel	Notes
Confirmed APT / Nation-State	1 hour (verbal) + 24 hours (written)	CISA US-CERT 888-282-0870 + us-cert.cisa.gov portal	Verbal first; written follows with full indicator set
C2 Beacons (Cat-B)	1 hour (verbal) + 24 hours (written)	CISA US-CERT + MS-ISAC portal	Include IOC list from TAXII feed match
Confirmed Exfiltration (Cat-J)	1 hour (verbal) + 24 hours (written)	CISA US-CERT + agency IG	Notify IG concurrently per M-26-14 §4.3
OT/ICS (Cat-E)	1 hour verbal; 4 hours written	CISA ICS-CERT + CISA US-CERT	Separate ICS-CERT channel required
Mass File Ops / Ransomware (Cat-K)	2 hours verbal; 24 hours written	CISA US-CERT + CISO + CIO	Internal escalation concurrent with CISA notification
All other CISA-notifiable	24 hours written	us-cert.cisa.gov portal	Use standard IR report form

2.3 Required Notification Fields

Every CISA notification, whether verbal or written, must include the following data elements. Prepare these from the Kibana Case before making the call or submitting the portal report.

- **Agency** — full legal agency name and FISMA system boundary name
- **Date and Time** — UTC timestamp of detection (`@timestamp` from the triggering alert) and UTC timestamp of notification
- **Affected Systems** — hostnames, IPs, asset types, and data sensitivity classification (CUI, classified, public)
- **Indicators of Compromise** — IP addresses, domains, file hashes (`log.hash.sha256`), registry keys, process names from the alert and correlated timeline
- **M-26-14 Category** — `m2614.category` value (Cat-A through Cat-K) and the specific detection rule that fired
- **Current Status** — Contained / Ongoing / Unknown; containment actions taken so far

2.4 Watcher Automation for High-Priority Notifications

The pack includes a Watcher action (`m2614-notify-soar`) that fires on Cat-B, Cat-E, Cat-J, and Cat-K rule matches. The Watcher posts a structured payload to the SOAR webhook (configured in Fleet → Integrations → SOAR Webhook). The SOAR platform is responsible for generating the notification draft; the analyst reviews and submits.

```
{
  "actions": {
    "notify_soar": {
      "webhook": {
        "method": "POST",
        "url": "{{ctx.payload.soar_webhook_url}}",
        "body": {
          "incident_id": "{{ctx.payload.hits.hits.0._id}}",
          "m2614_category": "{{ctx.payload.hits.hits.0._source.m2614.category}}",
          "host_name": "{{ctx.payload.hits.hits.0._source.host.name}}",
          "user_name": "{{ctx.payload.hits.hits.0._source.user.name}}",
          "rule_name": "{{ctx.payload.hits.hits.0._source.signal.rule.name}}",
          "timestamp": "{{ctx.payload.hits.hits.0._source.@timestamp}}",
          "kibana_alert_url": "{{ctx.metadata.kibana_alert_url}}",
          "notification_required": true,
          "cisa_sla_hours": "{{ctx.payload.cisa_sla_hours}}"
        }
      }
    }
  }
}
```

The `cisa_sla_hours` value is injected by the Watcher condition block based on the `m2614.category` match (1 for Cat-B/E/J, 2 for Cat-K, 24 for others). Confirm the webhook URL is set in the Watcher

configuration before going live.

3. POA&M Management

3.1 Purpose

A Plan of Action and Milestones (POA&M) documents compliance gaps identified against M-26-14 Appendix C elements and tracks remediation to closure. Under M-26-14, agencies must submit POA&Ms to CISA quarterly (see Section 3.4). The POA&M is also the primary evidence artifact for CIO and IG reviews.

3.2 Gap Detection

Gaps are surfaced by two mechanisms:

Automated (preferred): The following ML alert rules generate POA&M candidates when thresholds are breached. Each rule name maps to an Appendix C element:

ML Alert Rule	Element	Threshold Condition
m2614-ml-e1-coverage-drop	E1: Asset Coverage	Asset reporting rate falls below 95% for 24 hours
m2614-ml-e2-ingestion-rate	E2: Ingestion Rate	EPS drops more than 20% from 14-day baseline
m2614-ml-e3-rule-silence	E3: Rule Coverage	Detection rule produces zero alerts for 7 days (silence anomaly)
m2614-ml-e4-privop-spike	E4: Privileged Ops	Privileged operation volume anomaly score > 75
m2614-ml-e5-hash-coverage	E5: Log Integrity	SHA-256 hash coverage falls below 80% of ingested log volume

When any of these rules fires, the SOC analyst opens a Kibana Case tagged `poam-candidate`. The ISSO reviews these cases weekly and promotes confirmed gaps to POA&M items.

Manual: Quarterly review (Section 4) may surface gaps not caught by ML rules. Reviewers use the Maturity Overview dashboard to identify elements below target thresholds and manually create POA&M items.

3.3 POA&M Item Template

Each POA&M item must contain the following fields. Maintain this in a spreadsheet or GRC tool; the Kibana Case serves as the evidence record.

Field	Description	Example
Item ID	Sequential identifier	POA-2026-Q2-004
Element	Appendix C element (E1–E5)	E5: Log Integrity
Gap Description	Specific deficiency observed	SHA-256 hash coverage at 61%, below 80% threshold
Root Cause	Technical or process cause	<code>log-integrity-hash</code> pipeline not applied to syslog-legacy data stream
Planned Action	Specific remediation steps	Apply ingest pipeline to <code>logs-syslog.legacy-*</code> ; re-index 30 days of backlog
Responsible Party	Named individual or team	Security Engineering Team
Target Completion Date	Date	2026-07-15
Status	Open / In Progress / Closed	In Progress
Evidence Links	Kibana Case URL, dashboard screenshot URL	https://kibana.agency.gov/cases/POA-2026-Q2-004

3.4 Reporting Cadence

POA&M submissions to CISA follow the fiscal year quarterly schedule:

Quarter	Submission Deadline	Period Covered
Q1 (FY)	January 31	October 1 – December 31
Q2 (FY)	April 30	January 1 – March 31
Q3 (FY)	July 31	April 1 – June 30
Q4 (FY)	October 31	July 1 – September 30

Prepare the submission using the CISA-provided POA&M template (Excel or OSCAL JSON). Include all open and newly closed items. Attach the quarterly compliance report (Section 4.5) as a supporting artifact.

3.5 POA&M Closure Criteria

An item may be closed when both of the following conditions are met:

1. The relevant Appendix C element has been maintained at or above its threshold for **30 consecutive days**, as evidenced by the Maturity Overview dashboard trend line.
2. Evidence links in the Kibana Case include: a dashboard screenshot showing the passing threshold, the `integrity_verify.py` output (for E5 items), and the Security Engineer sign-off comment.

Closed items remain in the POA&M record for at least one year. Do not delete closed items.

4. Quarterly Compliance Review

4.1 Review Scope

The quarterly review assesses the health of all five Appendix C elements, the operational state of the pack components, and the completeness of the incident record. Participants: ISSO (owns the review), Security Engineer (technical findings), SOC Lead (incident summary), CISO or Deputy (sign-off).

Schedule the review no later than 10 business days before the POA&M submission deadline.

4.2 Review Checklist

Complete all items before drafting the quarterly report. Items marked with an asterisk are blocking — the report cannot be finalized if these are unresolved.

- ☐ * Hash coverage (`log.hash.sha256`) is present on $\geq 80\%$ of ingested log volume (E5 threshold)
- ☐ * All 11 Appendix B categories (Cat-A through Cat-K) have at least one ingesting data source
- ☐ * ILM policies `m2614-l3-hot-frozen` and `m2614-l4-hot-frozen` show correct phase transitions in Index Management
- ☐ * All 6 ML jobs are in `started` state with datafeeds running (`GET _ml/anomaly_detectors/_stats`)
- ☐ * All 39 custom detection rules are enabled and have triggered at least one alert in the past 90 days (or documented as expected-silent with justification)
- ☐ * Asset coverage (E1) $\geq 95\%$ of HWAM/CDM inventory reporting to Fleet
- ☐ * Ingestion rate (E2) is within 20% of the 14-day baseline (no prolonged EPS drops)
- ☐ * Rule coverage (E3) — no rules have been silent for > 30 days without documented justification
- ☐ Privileged operations (E4) — ML anomaly score trends reviewed; no unacknowledged high-score anomalies
- ☐ False positive rate reviewed for all 39 custom rules; tuning applied where FP rate $> 15\%$
- ☐ CISA notification log is current — all notifiable incidents from the quarter are logged with submission confirmation

- ☐ Fleet agent health: no agents offline for > 7 days without documented reason
- ☐ `integrity_verify.py` spot-check run against a random 5% sample of log indices; output reviewed
- ☐ CDM/HWAM sync confirmed: `fake-hwam-api` or production CDM endpoint returning current asset inventory
- ☐ Frozen tier restore test completed: at least one index restored from frozen tier; restore time documented
- ☐ TAXII feeds (CISA AIS, MS-ISAC) last-polled timestamp confirmed < 24 hours
- ☐ Logstash Splunk forwarding (HEC) health confirmed if in scope
- ☐ All open POA&M items reviewed for target date adherence; slipped items updated
- ☐ New POA&M items from this quarter drafted and assigned
- ☐ Quarterly report drafted and routed for CISO sign-off

4.3 Maturity Trend Analysis

Use the **Maturity Overview** dashboard as the primary source for trend analysis. Set the time picker to the quarter under review (90 days).

Focus areas:

- **E2: Ingestion Rate** — look for intra-day drops that correlate with maintenance windows or integration outages. Prolonged drops affect Appendix C attestation.
- **E3: Rule Coverage** — the `m2614-ml-e3-rule-silence` job surfaces rules that have gone quiet. Distinguish between legitimately quiet rules (no matching activity in the environment) and broken rules (data source offline, rule logic error).
- **E5: Hash Coverage** — the `m2614-ml-e5-hash-coverage` job tracks the percentage of events with a `log.hash.sha256` field. Downward trends indicate the `log-integrity-hash` pipeline is not applied to new data streams. Remediate before the 80% threshold is breached.

For each element, note the current score, the prior quarter score, and the trend direction. Include these in the quarterly report (Section 4.4).

4.4 Quarterly Report Template

Use the following template for the formal quarterly submission. Customize the placeholders with actual values. The CISO signs the Executive Summary.

```

# M-26-14 Compliance Quarterly Report
**Agency**: [Agency Name]
**Reporting Period**: [Quarter Start] - [Quarter End]
**Prepared By**: [ISSO Name]
**Approved By**: [CISO Name]
**Submission Date**: [Date]

## Executive Summary

[2-3 paragraphs summarizing overall compliance posture, notable improvements,
remaining gaps, and any CISA-notifiable incidents during the period. Written
by ISSO, signed by CISO.]

## Appendix C Element Scores

| Element | Description | Current Score | Prior Quarter | Trend | Status |
|-----|-----|-----|-----|-----|-----|
| E1 | Asset Coverage | XX% | XX% | Up / Down / Stable | Pass / Gap |
| E2 | Ingestion Rate | XX EPS avg | XX EPS avg | Up / Down / Stable | Pass / Gap |
| E3 | Rule Coverage | XX% active | XX% active | Up / Down / Stable | Pass / Gap |
| E4 | Privileged Ops | XX anomaly score | XX anomaly score | Up / Down / Stable | Pass /
| E5 | Log Integrity | XX% hash coverage | XX% hash coverage | Up / Down / Stable | Pass /

## Open POA&M Items

| Item ID | Element | Gap | Target Date | Status |
|-----|-----|-----|-----|-----|
| [ID] | [E1-E5] | [Summary] | [Date] | [Status] |

## Closed POA&M Items This Quarter

| Item ID | Element | Gap | Closed Date | Evidence |
|-----|-----|-----|-----|-----|
| [ID] | [E1-E5] | [Summary] | [Date] | [Kibana Case URL] |

## Notable Incidents

| Date | Category | Description | CISA Notified | Disposition |
|-----|-----|-----|-----|-----|
| [Date] | [Cat-X] | [Summary] | Yes / No | [TP/FP/Benign] |

## Recommendations

```


1. [Specific, actionable recommendation with owner and target date]
2. [Specific, actionable recommendation with owner and target date]
3. [Specific, actionable recommendation with owner and target date]

5. ML Job Operations

5.1 Health Monitoring

Check ML job health weekly and before any quarterly review. A job that has stopped generating anomaly scores will not surface POA&M candidates automatically.

```
GET _ml/anomaly_detectors/_stats
```

For each of the six M-26-14 jobs, confirm:

Check	Expected Value
state	opened
datafeed_state	started
model_snapshot_id	Present (not null)
Last bucket processed	Within the past 24 hours

Jobs: element1-asset-coverage, element2-ingestion-rate, element3-rule-silence, element4-privop-spike, element5-hash-coverage, catb-dns-entropy

If last_bucket_timestamp is more than 24 hours old and the job is opened, the datafeed is likely stopped or the source index is empty.

5.2 Restart Procedure

Use the Kibana Dev Console for all restart operations. Do not use the ML UI for bulk operations — the API is more reliable for scripted procedures.

```
# Step 1: Stop the datafeed
POST _ml/datafeeds/datafeed-element2-ingestion-rate/_stop

# Step 2: Close the job
POST _ml/anomaly_detectors/element2-ingestion-rate/_close

# Step 3: Reopen the job
POST _ml/anomaly_detectors/element2-ingestion-rate/_open

# Step 4: Start the datafeed from the last processed bucket
POST _ml/datafeeds/datafeed-element2-ingestion-rate/_start
{
  "start": "now-1d"
}
```

Substitute the job and datafeed names as appropriate. Run `GET _ml/anomaly_detectors/element2-ingestion-rate/_stats` after Step 4 to confirm the datafeed is in `started` state and processing buckets.

5.3 Baseline Drift

ML jobs use a 14-day stabilization period after initial deployment. During this window, anomaly scores will be elevated as the model learns the environment baseline. Do not create POA&M items from ML alerts generated within the first 14 days of job deployment.

After bulk asset onboarding (more than 20% increase in agent count), the model baseline may drift. Refresh the model by closing the job and reopening it — this triggers a new baseline window. Document the refresh date in the Security Engineer's runbook log.

5.4 Alert Score Tuning

The default anomaly score threshold for all 13 ML alert rules is 50. After 30 days of operation, review the alert volume and score distribution using the ML Anomaly Explorer.

Tuning guidelines:

- If the alert rule is generating more than 10 alerts per day with < 20% true positive rate, raise the threshold to 65–75.
- If high-severity anomalies are being missed (confirmed incidents not preceded by ML alerts), lower the threshold to 35–45.
- Document every threshold change in the rule description field and the ISSO's change log.

Threshold changes are managed in Kibana Security → Rules → [ML rule name] → Edit → Score threshold. Do not change the underlying ML job — only the alert rule threshold.

6. ILM and Retention Compliance

6.1 Retention Monitoring

The **Log Management** and **Retention Compliance** dashboards provide per-index visibility into ILM phase, age, and transition status. Review these dashboards during the quarterly review and after any infrastructure change.

M-26-14 mandates retention tiers that map to ILM phases:

Log Level	Hot Phase	Warm Phase	Frozen Phase	Total Retention
L3 (standard)	30 days	60 days	12 months	~15 months
L4 (enhanced)	30 days	60 days	24 months	~27 months

ILM policies `m2614-l3-hot-frozen` and `m2614-l4-hot-frozen` implement these tiers. Confirm that all M-26-14 data streams are using the correct policy in Index Management → Data Streams.

6.2 Watcher Alert for Missed Phase Transitions

A Watcher alert fires if any index assigned to an M-26-14 ILM policy has been in the current phase longer than 2x the expected phase duration. This indicates an ILM execution error (insufficient disk space, repository misconfiguration, or node availability issue).

When this alert fires:

1. Check `GET /<index>/_ilm/explain` for the specific index.
2. Resolve the underlying infrastructure issue (disk space, snapshot repository, node health).
3. Retry the ILM step: `POST /<index>/_ilm/retry`.
4. Confirm the transition completed within 24 hours.
5. Document in the ISSO runbook if the delay exceeded 72 hours.

6.3 Frozen Tier Restore Testing

Quarterly, perform a spot restore from the frozen tier to confirm data integrity and measure restore time. Document the restore time in the quarterly report.

Procedure:

1. Identify an index in the frozen phase that is at least 90 days old.
2. Partially mount the index using the snapshot repository:

```
POST _snapshot/<repository>/<snapshot>/_mount
{
  "index": "<source-index>",
  "renamed_index": "<source-index>-restore-test",
  "index_settings": {
    "index.number_of_replicas": 0
  }
}
```

3. Run a sample query against the restored index (search for 10 documents).
4. Record the restore time from mount request to first query result.
5. Delete the restore-test index after validation.

Target restore time: < 15 minutes for a standard daily index. If restore time exceeds 30 minutes, investigate snapshot repository performance and document the finding.

7. Detection Rule Operations

7.1 Bulk Enable

After initial deployment or after a configuration reset, enable all 39 custom M-26-14 detection rules using the setup script:

```
python tools/setup_ws5.py --enable
```

Confirm by checking Kibana Security → Rules and filtering by tag `m2614`. All 39 rules should show status `Active`.

7.2 False Positive Management

When a detection rule generates a confirmed false positive:

1. In the alert detail, click **Add exception**. Create a rule-level exception (not a global exception) with the specific field-value pair that defines the benign condition.
2. Add a comment to the exception describing the asset, user, or process that generates the benign activity and why it is expected.
3. Open a Kibana Case with disposition `False Positive` and link the exception to the case.
4. Do not disable the rule. A disabled rule creates an E3 gap (rule coverage).

If the same rule generates > 15% false positive rate over a 30-day period, escalate to the Security Engineer for rule logic review. The exception list may need to be restructured, or the rule may need to be cloned and modified for the agency's specific environment (see Section 7.4).

7.3 Rule Updates

When a new version of the M-26-14 pack is released:

1. Update the pack using `elastic-package upgrade` in the pack source directory.
2. Deploy the update to a staging Fleet environment first.
3. Validate that custom exceptions carry over correctly (they are rule-level, so they survive rule upgrades).
4. Test that all 39 rules trigger correctly against the staging dataset.
5. Apply to production Fleet environment during a scheduled maintenance window.
6. Confirm rule counts and statuses post-upgrade.

7.4 Custom Rule Modifications

If a detection rule requires logic changes specific to the agency environment (custom field names, environment-specific baselines):

1. Clone the rule in Kibana Security → Rules → Duplicate.
2. Modify the cloned rule. Name it with an agency prefix (e.g., `[AGENCY] m2614-cat-b-c2-beacon-custom`).
3. Tag the cloned rule with both `m2614` and `agency-custom`.
4. Disable the original rule (document the reason in the original rule's description field).
5. Record the modification in the ISSO change log.

Do not modify pack-managed rules in place. Pack upgrades will overwrite unprotected modifications.

Appendix A: Runbook — High-Priority Alert (Cat-B C2 Beacons)

This runbook covers the complete response to a Cat-B (Command and Control beacons) alert. Adapt for Cat-E with ICS-CERT notification substituted for CISA US-CERT SOC channel.

Triggering alert: Rule `m2614-cat-b-c2-beacon` fires with a match against a known-bad IP or domain from the CISA AIS or MS-ISAC TAXII feed.

Step 1 — Detect

Alert appears in Kibana Security → Alerts with `m2614.category: Cat-B`. Watcher action `m2614-notify-soar` fires automatically within 60 seconds of alert creation, posting to the SOAR webhook.

Step 2 — Verify

- Open the alert. Confirm `m2614.category: Cat-B` and `threat.indicator.ip` or `threat.indicator.domain` matches a TAXII feed entry.
- Check the correlated timeline: look for DNS queries, network connections, and process activity on `host.name` in the 30 minutes before and after the alert `@timestamp`.
- Check `log.hash.sha256` for the originating process. Run hash against VirusTotal or agency threat intel platform.
- Check for lateral movement: query `process.parent.name` across all hosts in the same subnet for the same process hash.
- Decision: if the indicator match is to a high-confidence feed entry (CISA AIS TLP:AMBER or TLP:RED) and corroborated by process or DNS evidence, declare True Positive and proceed to Step 3.

Step 3 — Escalate

- Call the on-call security lead (SOAR should have already paged them; confirm acknowledgment).
- Notify the ISSO and CISO within 30 minutes of True Positive declaration.
- Assign P1 in the SOAR case. Link the Kibana alert ID.
- Start the 1-hour verbal notification clock for CISA.

Step 4 — Contain

- Isolate the affected host via Fleet → Agents → [Agent] → **Isolate Host**. This drops all network traffic except Elastic Agent communications.
- If the affected host is a server with critical services, coordinate with system owner before isolating. Do not delay isolation more than 15 minutes for coordination.
- Block the C2 IP/domain at the network perimeter (firewall, DNS RPZ, proxy deny-list). Submit the IOC to the network security team with priority escalation.
- Revoke active sessions for any accounts observed in the 30-minute correlated timeline (particularly any privileged accounts).

Step 5 — Notify CISA

- Call CISA US-CERT: 888-282-0870. Provide:
 - Agency name and FISMA system boundary
 - UTC detection timestamp
 - C2 indicator (IP or domain)
 - `log.hash.sha256` of implicated process if available
 - Affected host count
 - Containment actions taken
 - Current status: Contained / Ongoing

- Submit written notification via us-cert.cisa.gov portal within 24 hours with full indicator set, timeline, and Kibana Case URL (if portal accepts external URLs) or attached timeline export.
- Update the Kibana Case field `CISA Notification Status` to `Submitted`.

Step 6 — Document

- Open a Kibana Case (if not already open from SOAR). Set all required fields per Section 1.4.
- Export the alert timeline (Kibana Timeline → Export) and attach to the case.
- Run `integrity_verify.py` against the indices covering the incident window to confirm log tamper evidence is clean. Attach the output to the case.
- Document all containment actions with timestamps in the case comments.

Step 7 — Close

- After forensic investigation is complete and remediation is underway:
 - Set disposition: `True Positive`.
 - Update `CISA Notification Status` to `Acknowledged` once CISA confirms receipt.
 - Create a POA&M item if the incident exposed a compliance gap (e.g., the implanted process had no SHA-256 hash coverage, indicating an E5 gap).
 - Brief the CISO within 48 hours using the case summary.
 - Close the case. Do not delete — retain for one year minimum.
-

Appendix B: Alert Category Quick Reference

Category	M-26-14 §5 Reference	Rule Pattern	Default Priority	CISA Notifiable
Cat-A	§5.1 — Authentication Events	Failed/successful auth, MFA bypass, credential stuffing	P3	No (unless confirmed APT)
Cat-B	§5.2 — Command and Control	C2 beaconing, known-bad TI match, DNS tunneling	P1	Yes — 1-hour verbal
Cat-C	§5.3 — Network Anomalies	Unusual protocols, port scanning, East-West anomalies	P3	No
Cat-D	§5.4 — Endpoint Anomalies	Process injection, hollow process, unusual parent-child	P3	No (unless confirmed malware)
Cat-E	§5.5 — OT/ICS	ICS protocol anomalies, engineering workstation access, Modbus/DNP3 anomalies	P1	Yes — 1-hour verbal (ICS-CERT)
Cat-F	§5.6 — Cloud Events	Cloud API abuse, IAM privilege escalation, storage exfil	P3	No (unless confirmed exfil)
Cat-G	§5.7 — Email Threats	Phishing delivery, BEC indicators, malicious attachment	P3	No

Category	M-26-14 §5 Reference	Rule Pattern	Default Priority	CISA Notifiable
Cat-H	§5.8 — Privileged Access	Off-hours privileged login, admin tool use outside baseline, PAM bypass	P2	No (unless confirmed compromise)
Cat-I	§5.9 — Asset Anomalies	New unmanaged host, rogue device, CDM coverage gap	P3	No
Cat-J	§5.10 — Exfiltration	Large outbound transfers, staging-and-exfil pattern, DLP alert correlation	P2	Yes — 1-hour verbal
Cat-K	§5.11 — Malware/Lateral Movement	Ransomware indicators, lateral movement TTPs, worm-like spread	P2	Yes — 2-hour verbal